



OWASP
Smart Contract Security

scs.owasp.org

Security Handbook : Employee Lifecycle

03

Security Handbook Series

GRANT SUPPORT • 2025-2026



ecosystem
support
program

Supported by Ethereum Foundation's
Ecosystem Support Program (ESP)



Contents

Frontispiece	4
About This Handbook	4
Copyright and License	5
Author and Creative Credits	5
Purpose and Scope	6
Target Audience	6
How to Use This Handbook	6
Relationship to SCSVS, SCSTG, and SCWE	7
Part I: Foundations	8
1. Introduction to Lifecycle Security	8
Part II: Onboarding	18
2. Pre-Onboarding	18
3. Access Provisioning	23
4. Training and Awareness	29
5. Checklist and Documentation	32
Part III: Offboarding	37
6. Offboarding Triggers and Timing	37
7. Access Revocation	41
8. Asset and Key Recovery	45
9. Checklist and Documentation	47
10. Legal and HR Coordination	50
Part IV: Special Considerations	52
11. Contractors and Short-Term Roles	52
12. Remote and Distributed Teams	54
13. High-Risk Roles (Treasury, Deploy Keys, Admin)	56
14. Multisig and Protocol Signer Lifecycle	59
15. Succession and Backup for Key Roles	62
Part V: Appendices	64
16. Appendix A: Glossary	64
17. Appendix B: Onboarding Checklist (Printable)	69
18. Appendix C: Offboarding Checklist (Printable)	71
19. Appendix D: References and Further Reading	73

Appendix C: References and Further Reading 75

Standards and Frameworks 75

Incidents and Case Studies..... 75

Tools and Documentation..... 76

Further Reading..... 76

Frontispiece

OWASP SMART CONTRACT SECURITY PROJECT

Employee Lifecycle Security

About This Handbook

Employee Lifecycle Security is part of the OWASP Smart Contract Security Handbook Series. The series extends smart contract security beyond contract code into the people, process, application, infrastructure, and operational layers surrounding Web3 systems.

Each handbook is designed as a defensive field reference for architects, engineers, security practitioners, incident responders, auditors, and organizational leaders. It complements the OWASP Smart Contract Security Verification Standard (SCSVS), Smart Contract Security Testing Guide (SCSTG), Smart Contract Weakness Enumeration (SCWE), Smart Contract Top 10, and SCS Checklist without replacing those resources.

SERIES EDITION **2026**

Copyright and License

Copyright © 2026 The OWASP Foundation and contributors.



This document is released under the [Creative Commons Attribution-ShareAlike 4.0 International License](#). You may share and adapt the material with appropriate attribution and under the same license. For reuse or distribution, make the license terms clear and identify material changes.

OWASP publications are community-developed educational resources. References to organizations, products, or services do not constitute endorsement, and the material is provided without warranty.

Author and Creative Credits

PROJECT LEAD

Shashank | CredShields

CEO and Co-Founder

AUTHOR | PROJECT MAINTAINER

Pratik Lagaskar

Security Researcher

COVER PAGE DESIGNS

Siddharth Neekher

Lead UI Designer @ CredShields

OWASP Smart Contract Security Project

Purpose and Scope

This handbook sets guidelines for securing the full employee lifecycle in Web3 and crypto-native organizations: pre-onboarding screening, least-privilege access provisioning, and the offboarding and revocation work that most teams treat as an afterthought. It is grounded in current practice: access-centric offboarding that coordinates HR, IT, and compliance rather than leaving revocation to a single team; zero-trust rapid revocation backed by identity and device management tooling; and automated identity lifecycle management (identity and access management, IAM, paired with identity governance and administration, IGA) that closes the gap between an employee's actual role and the privileges still attached to their account. The scope runs from background verification through key and credential handling, role-based access design, and the timely revocation that keeps a departure from becoming a breach, set against the compliance backdrop of SOC 2 (System and Organization Controls 2), the Sarbanes-Oxley Act (SOX), and the Payment Card Industry Data Security Standard (PCI DSS) where they apply.

Web3 raises the stakes on lifecycle security in ways a traditional SaaS company does not face. A departing engineer at a Web2 firm loses access to a dashboard; a departing engineer at a Web3 firm may still hold a multisig signer key, a deploy credential, or treasury access that no offboarding ticket can claw back once it has left their laptop. The 2022 compromise of Ronin Network's validator keys, reportedly traced to a fraudulent job offer sent to an engineer, and the pattern of Democratic People's Republic of Korea (DPRK) operatives posing as remote contractors, documented in joint advisories from the Federal Bureau of Investigation (FBI) and the Cybersecurity and Infrastructure Security Agency (CISA), both show that the employee lifecycle, not just the smart contract, is where many of the largest Web3 losses actually start. This handbook treats onboarding and offboarding as security-critical processes owned jointly by HR, IT, security, and legal, not as paperwork that happens after the security work is done.

Target Audience

HR, operations, security, and team leads in Web3 and crypto-native organizations responsible for the hiring, access provisioning, and offboarding of employees, contractors, and protocol signers.

How to Use This Handbook

Read Part I first to fix the vocabulary, the access types unique to Web3 organizations (infrastructure, code, treasury, and communications), and why offboarding belongs to security rather than HR alone. Part II is the onboarding reference: pre-onboarding checks, least-privilege access provisioning, security training, and the checklist that closes the loop. Part III mirrors it for

offboarding: triggers and timing, revocation across every system a departing employee touched, asset and key recovery, and the legal and HR coordination that documentation and audit trails require. Part IV covers the roles that need special handling: contractors, remote and distributed staff, treasury and deploy-key holders, and multisig signers, plus succession planning for roles a single departure could otherwise leave uncovered. The appendices hold a glossary and printable onboarding and offboarding checklists for teams that want a working template today.

Relationship to SCSVS, SCSTG, and SCWE

This handbook complements the OWASP smart contract standards without duplicating them. The Smart Contract Security Verification Standard (SCSVS) defines the controls a system must satisfy, including the access control and key management requirements that pre-onboarding and offboarding here exist to enforce day to day. The Smart Contract Security Testing Guide (SCSTG) describes how to test those controls; the audit trail and verification steps in Parts II and III give testers the process evidence the SCSTG asks them to check for. The Smart Contract Weakness Enumeration (SCWE) catalogs weaknesses in contract code; an orphaned deploy key or a multisig signer who never handed back their role sits upstream of many of those weaknesses, an organizational gap the enumeration does not itself track. Two companion handbooks share this ground directly: the Hiring, Remote Work, and Insider Threat Handbook (05) covers the vetting and insider-risk detection that pre-onboarding here depends on, and the Web3 Operational Security Handbook (11) owns the day-to-day key hygiene and communications discipline that this handbook's provisioning and revocation controls are designed to protect.

Part I: Foundations

This part fixes the vocabulary and the threat model that the rest of the handbook builds on. It explains why the employee lifecycle is a Web3-specific attack surface rather than a generic HR concern, catalogs the four categories of access a Web3 organization must track from hire to departure, and positions offboarding as a control owned jointly by security, IT, and HR rather than as paperwork that happens after the real security work is done.

1. Introduction to Lifecycle Security

1.1 Why Onboarding/Offboarding Matters in Web3

A traditional software company's employee lifecycle is mostly a productivity problem: give people the tools they need on day one, take the tools back on the last day, and the worst-case failure is a lingering login to an internal wiki. A Web3 organization runs the same lifecycle over a fundamentally different risk surface. The accounts being provisioned and revoked can include a private key that moves treasury funds directly, a role in a smart contract's admin multisignature wallet (multisig), or write access to the repository that builds the code an audience of users will trust with their savings. Get offboarding wrong at a Web2 company and someone reads an old file. Get it wrong at a Web3 company and someone can drain a treasury, because blockchain transactions settle irreversibly and there is no chargeback once a signature is broadcast.

The industry's largest incidents bear this out. On March 23, 2022, attackers compromised five of the nine validator nodes securing the Ronin Network, the sidechain behind the game Axie Infinity, and drained roughly 173,600 ETH and 25.5 million USDC, worth about \$625 million at the time ([Ronin Network incident summary](#)). The FBI publicly attributed the theft to the North Korean state-sponsored Lazarus Group and APT38 on April 14, 2022. Four of the five compromised validators belonged to Sky Mavis, the company behind Ronin, but the fifth belonged to the Axie DAO, a nominally independent third party. Sky Mavis had no business signing on the DAO's behalf by March 2022: the DAO had granted Sky Mavis a temporary allowlist permission in November 2021 to help handle a surge in transaction load, that permission expired the following month, and it was never revoked. The attacker used the still-live allowlist entry to forge the fifth signature

needed to approve the fraudulent withdrawal (Halborn, “Explained: The Ronin Hack (March 2022)”). A stale, unrevoked access grant, exactly the kind of artifact this handbook exists to prevent, was load-bearing in one of the largest thefts in crypto history.

The lifecycle is also targeted directly as an entry point. The FBI, together with the U.S. Department of State and Republic of Korea agencies, issued a joint public service announcement on October 18, 2023 warning that Democratic People’s Republic of Korea (DPRK) operatives were systematically obtaining remote IT jobs at Western companies, including crypto and Web3 firms, using stolen or fabricated identities (FBI IC3 PSA 231018). The advisory lists concrete red flags: candidates who refuse video interviews, whose location and stated timezone do not match, who ship company laptops to freight-forwarding addresses, or who later threaten to leak proprietary code after termination. This is not a hypothetical: Chainalysis’s 2025 Crypto Crime Report found that North Korean-linked actors stole \$1.34 billion from crypto platforms in 2024 alone, 61% of all crypto stolen that year, with a growing share tied to IT-worker infiltration of the exact hiring pipeline that Part II of this handbook hardens. In Web3, the employee lifecycle is not adjacent to the attack surface. It is the attack surface.

1.2 Key and Access Types (Infra, Code, Treasury, Comms)

Before you can provision or revoke access correctly, you need a shared vocabulary for what “access” even means at a Web3 organization. Four categories recur across every chapter in this handbook, and each carries a different blast radius if mishandled.

Category	Examples	Typical blast radius if compromised or orphaned
Infrastructure	Cloud console (AWS, GCP, Azure), Kubernetes clusters, RPC node operator panels, VPN, SSO/identity provider, secrets managers	Full environment takeover, lateral movement into every downstream system

Category	Examples	Typical blast radius if compromised or orphaned
Code	Git hosting (GitHub, GitLab), CI/CD pipelines and their secrets, package registry publishing rights, deploy keys for smart contracts	Malicious commits, backdoored releases, contract redeployment with attacker-controlled logic
Treasury	Multisig signer keys, hardware wallet seed material, custodial exchange accounts, DAO governance voting power, hot wallet API keys	Direct, irreversible fund loss; governance capture
Communications	Company email, Slack/Discord admin, social media accounts, domain registrar and DNS panel, incident-response contact lists	Phishing launched from a trusted identity, brand-damaging impersonation, DNS hijack that redirects users to a malicious front end

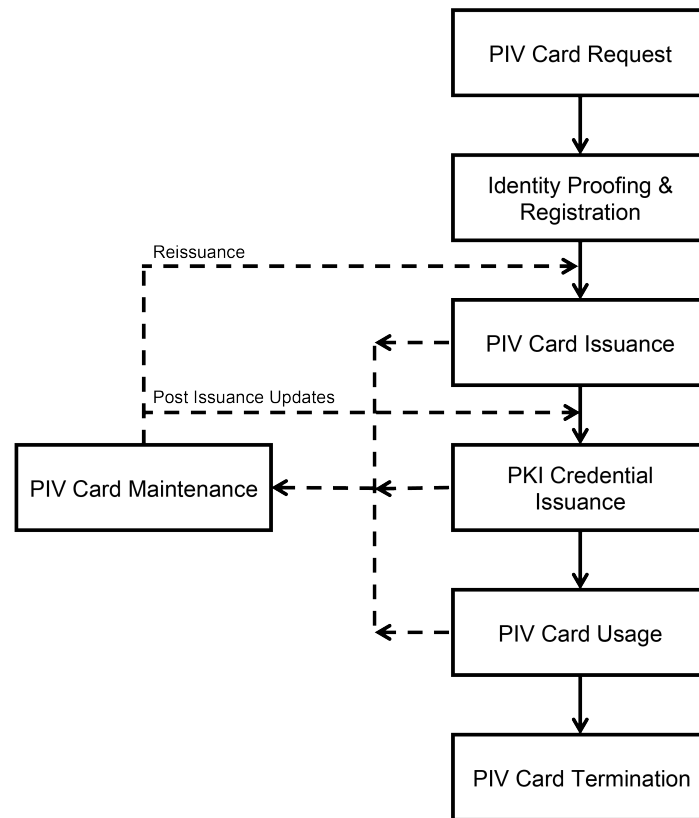


Figure. NIST's PIV card lifecycle is a useful control model even when the credential is a passkey, cloud identity, or hardware wallet: sponsorship and identity proofing precede issuance; maintenance, renewal, and replacement are explicit states; and termination is a first-class lifecycle event rather than an informal cleanup task. Source: *NIST FIPS 201-3, PIV Card Life Cycle*, public domain (U.S. government work).

Two properties distinguish this table from its Web2 equivalent. First, treasury access has no analog in most traditional companies: a departing employee with an active multisig signer role or an unrotated hot wallet key is a category of risk that generic offboarding checklists were never built to catch. Second, the categories interact. A compromised infrastructure credential can be used to pivot into a CI/CD pipeline (code), which can be used to push a malicious release that drains a treasury, which can then be laundered through a compromised communications channel used to social-engineer support staff. Chapter 3 (Part II) and Chapter 7 (Part III) map each category to concrete provisioning and revocation procedures; this table is the shared reference they both point back to.

1.3 Offboarding as Security-Critical (Not Just HR)

Most organizations, Web3 included, still route offboarding primarily through HR: a departure is logged, a final paycheck is calculated, an exit interview is scheduled, and IT is looped in as a downstream administrative task rather than a security control with its own deadline and owner.

That model fails the moment any of the access types in Section 1.2 is in scope, because HR systems were not built to track a multisig signer role or a deploy key and have no mechanism to force its revocation before the employee's device leaves the building.

The Ronin case in Section 1.1 is the clearest illustration available: the failure was not that Sky Mavis granted access it should never have granted. Granting the Axie DAO temporary signing rights during a load spike was a reasonable operational decision. The failure was that nobody owned the deadline. The permission had an implicit expiration (the load spike ended), nobody translated that into an explicit revocation task, and the access sat live and forgotten for roughly four months until an attacker who had already compromised four other validators used it to reach quorum. That is an offboarding failure in exactly the same shape as a departing engineer keeping a laptop VPN profile: a grant that should have had a clear owner and a clear end date instead had neither.

Treat offboarding as security-critical means giving it the same rigor as any other control with a service-level target: a named owner (security or IT, not HR alone), a maximum time-to-revoke measured in hours for high-risk access and same-day for everything else, and a completion record that someone other than the revoker checks. HR remains essential, since it is usually the first system of record for a departure date and the legal owner of confidentiality obligations (Chapter 10 in Part III), but it is a stakeholder and trigger source, not the control owner. Section 1.4 explains the mechanism that makes this practical at scale, and Chapter 6 in Part III returns to triggers and timing in full detail.

1.4 Automated vs. Manual Lifecycle: Privilege Creep and Orphaned Identities

A manual lifecycle, where a human files a ticket to grant access and another human files a ticket to revoke it, works for a five-person team and degrades predictably as headcount, tooling, and role changes accumulate. Two failure modes dominate the literature and match what shows up in real incidents.

Privilege creep is the steady accumulation of access rights beyond what a person's current role requires. It happens through entirely ordinary events: an engineer moves from one team to another and keeps the old team's repository access because nobody remembered to remove it; someone covers an on-call rotation for two weeks and retains the elevated production access afterward; a contractor's short-term project extends twice and their scope of access never gets re-scoped to match. Each individual grant looked reasonable at the moment it was made. The aggregate, months later, is a person holding far more access than their job justifies, and every one of those extra grants is a credential an attacker can exploit if that person's account, device, or session is ever compromised.

Orphaned identities are accounts, keys, or roles that persist after the person they belonged to has left, been reassigned, or the system that tracked them has changed. They are the direct residue of offboarding failures: the departed contractor's API key still valid in a secrets manager,

the SSH key still in an `authorized_keys` file, the multisig signer slot never handed back. Orphaned identities are attractive to attackers precisely because nobody is watching them: no one notices unusual activity on an account they believe is already gone.

Both failure modes compound under a purely manual process because manual revocation depends on someone remembering to act, and organizations reliably do not remember at scale. This is the problem identity governance and administration (IGA) tooling exists to solve: automated identity lifecycle management ties access grants to an authoritative source (an HR system, a role definition, a project assignment) and automatically re-certifies or revokes access when that source changes, rather than depending on a human to file the follow-up ticket. **NIST's identity and access management (IAM) program** frames the goal precisely: ensuring “the right people and things have the right access to the right resources at the right time,” a formulation that only holds if the “right time” includes the moment access should end, not only the moment it should begin.

The cost of getting this wrong is measurable. The 2022 Ponemon Institute Cost of Insider Threats study, sponsored by Proofpoint, found the average cost per insider-related incident had risen to \$15.38 million, that containment time had grown to 85 days on average, and that incidents taking more than 90 days to contain cost organizations an average of \$17.19 million annualized (**Ponemon/Proofpoint Cost of Insider Threats Report**). Credential-theft-related incidents alone cost organizations an average of \$4.6 million, up 65% from two years earlier. Neither figure is Web3-specific, which is the point: the underlying failure (access that should have been removed and was not) is a universal enterprise problem, and Web3 organizations inherit it while adding treasury-category access that turns the same failure into an irreversible fund loss rather than a data-exposure incident.

The insider threat mitigation framework allows for consistent, systematic mitigation of insider threats, encouraging engagement across all organizational operations and functions. The combination of cultural and systemic action will fulfill **five core functions**:

- 1 Establish and maintain a safe environment** to prevent violence and other hostile acts from occurring
- 2 Deter potential insider threats** by instituting policies, security controls, procedures, and programs to protect the organization
- 3 Detect threatening or concerning behaviors** and identify individuals at risk of becoming an insider threat
- 4 Assess information about actual or potential insider threats**
- 5 Manage potential insider threats before they escalate** to violence, espionage, sabotage, or theft

Figure. CISA's five-function insider-threat model clarifies where lifecycle controls sit: automated provisioning and revocation primarily deter abuse, expose signals for detection and assessment, and give the response team a reliable mechanism to suspend access during management of a confirmed threat. Source: [CISA Insider Threat Mitigation Guide](#), page 27, public domain (U.S. government work).

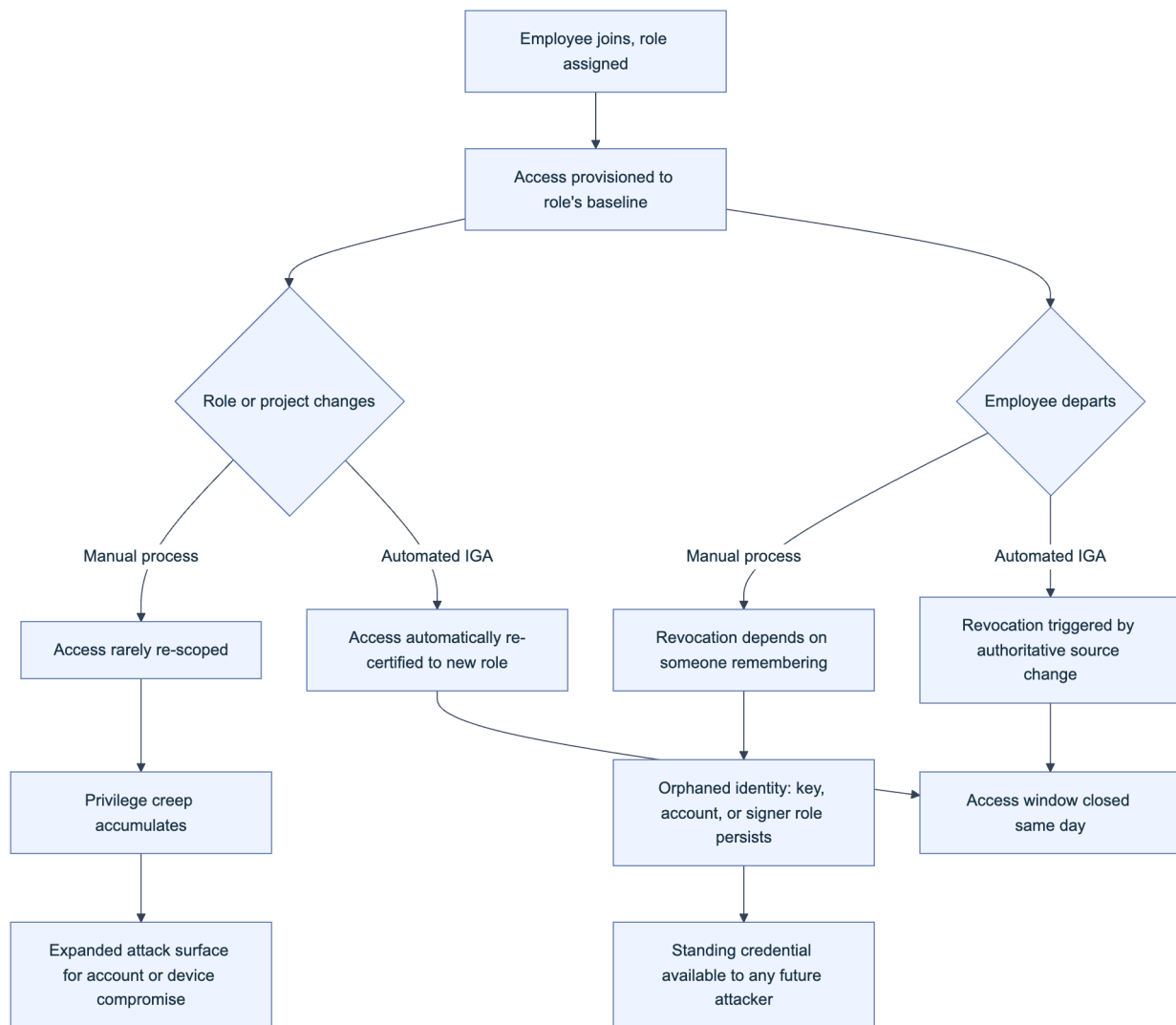


Figure 1. Manual versus automated identity lifecycle paths. The two failure modes, privilege creep and orphaned identities, both trace back to a lifecycle event (role change or departure) that never propagated to the access layer.

No organization eliminates manual steps entirely, and Part II and Part III both include manual checklist templates precisely because most Web3 organizations, especially smaller ones, will run a hybrid model for years. The design goal is to shrink the manual surface to the access types that genuinely require human judgment (a treasury role handback, a multisig re-key) and automate everything that follows a predictable rule (a repository permission tied to a team assignment, an SSO group tied to a department).

1.5 Relationship to OpSec and IAM

Lifecycle security sits at the intersection of two disciplines this handbook does not fully own: identity and access management, and operational security (OpSec). Understanding the boundary helps you route a given control to the right owner and the right handbook.

IAM is the technical substrate: the directory service, the single sign-on (SSO) provider, the role definitions, and the enforcement points (VPN, cloud IAM policies, repository permissions) that actually grant or deny a request. [NIST SP 800-207, Zero Trust Architecture](#) (August 2020), re-frames what IAM should guarantee under modern threat conditions: authentication and authorization are discrete, per-session functions evaluated before every access to an enterprise resource, and no implicit trust is granted based on network location or prior access. That framing matters directly for lifecycle security, because a zero-trust posture makes offboarding failures less catastrophic by design: if every session requires fresh authorization rather than trusting a standing VPN tunnel, an orphaned credential has a shorter effective half-life even when a human forgets to revoke it explicitly. Section 3.1 (Part II) and Chapter 7 (Part III) apply this principle to concrete provisioning and revocation procedures.

IGA, introduced in Section 1.4, is the governance layer built on top of IAM: it answers *who should have what access, for how long, and who approved it*, and automates the certification and revocation cycle. This handbook treats IGA as the mechanism, not the policy; the policy questions (what does least privilege mean for a smart contract deployer, what does a multisig signer’s role actually require) are lifecycle security questions this handbook answers directly.

OpSec, covered end to end in the [Web3 Operational Security Handbook](#) (11), is the day-to-day discipline an individual and a team practice regardless of what the IAM system grants them: how a signer stores a seed phrase, how a team verifies a counterparty’s identity before a call, how communications are compartmentalized so a single compromised channel cannot cascade. Lifecycle security and OpSec meet at the moment of onboarding and offboarding: this handbook’s job is to grant the right access at hire and remove all of it at departure; the OpSec handbook’s job is to govern how that access is used safely in between. The [Hiring, Remote Work, and Insider Threat Handbook](#) (05) is the third point of this triangle, covering the pre-employment vetting (including DPRK IT-worker detection per Section 1.1) that determines whether someone should be granted access at all, before this handbook’s provisioning controls ever engage. The [OWASP Smart Contract Security Verification Standard \(SCSVS\)](#) formalizes the access-control and key-management requirements a system must satisfy technically; this handbook is the organizational process that keeps those requirements true as people join, change roles, and leave.

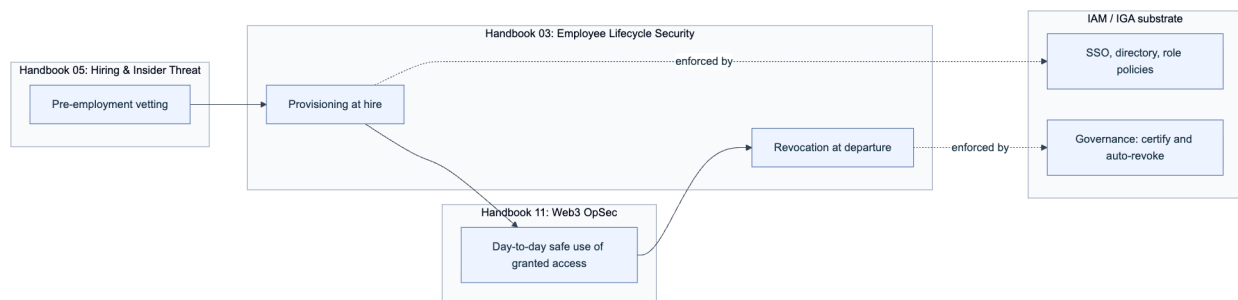


Figure 2. Where lifecycle security sits relative to pre-employment vetting, day-to-day OpSec, and the underlying IAM/IGA technical substrate.

1.6 How to Use This Handbook

Read this Part once to fix the vocabulary: the four access categories from Section 1.2, the automated-versus-manual framing from Section 1.4, and the boundary with IAM and OpSec from Section 1.5. After that, treat the handbook as a reference you jump into at the point relevant to your task. Part II is the onboarding path in order: pre-onboarding screening, least-privilege access provisioning mapped to the categories in Section 1.2, security training, and a checklist template that closes the loop with an audit trail. Part III mirrors that structure for offboarding: what triggers a revocation and how fast it must happen, category-by-category revocation procedures, asset and key recovery, and the legal and HR coordination that documentation requires; read it before you need it, not during an actual departure. Part IV addresses roles that need handling beyond the standard template: contractors, remote and distributed staff, treasury and deploy-key holders, and multisig signers, plus succession planning so that a single person's departure never leaves a critical role uncovered. The appendices hold a glossary and printable checklist templates you can adapt directly into a runbook.

Cross-references point outward deliberately. Where a control depends on pre-employment vetting or insider-threat indicators, the text points to Handbook 05. Where it depends on the safe daily use of a credential once granted, it points to Handbook 11. Where it depends on infrastructure-level controls such as SSO hardening or secrets management architecture, it points to the Infrastructure Security Handbook (07). Follow those threads outward when a topic in this handbook touches a system this handbook does not itself own.

Key controls for Part 1

- Track access in the four categories that matter for Web3: infrastructure, code, treasury, and communications, since treasury access has no Web2 analog and demands its own procedures.
- Own offboarding as a security control with a named owner and a maximum time-to-revoke, not as an HR administrative afterthought.
- Assume every standing, unreviewed access grant has an implicit expiration; the Ronin incident shows what happens when nobody tracks it.
- Move toward automated identity governance (IGA) for any access tied to a role or project, and reserve manual process for access that genuinely requires human judgment, such as treasury and multisig roles.
- Screen new hires against known infiltration patterns, including the DPRK IT-worker red flags in the FBI's October 2023 advisory, before granting any access at all.

Part II: Onboarding

This part walks the onboarding path in the order a Web3 organization should actually run it: verify who you are hiring within the limits the law allows, provision access to the four categories from Part 1 (infrastructure, code, treasury, communications) strictly by role, train the person before you hand them anything sensitive, and close the loop with a checklist and an audit trail someone other than the hiring manager can review. Every control here exists because a Web3 employee, unlike most Web2 hires, may end day one with the ability to move irreversible funds.

2. Pre-Onboarding

Pre-onboarding is everything that happens between an accepted offer and a person's first login. Get this phase right and access provisioning in Chapter 3 becomes a matter of following a known-good role template; get it wrong and you are granting infrastructure, code, or treasury access to an identity nobody has actually verified.

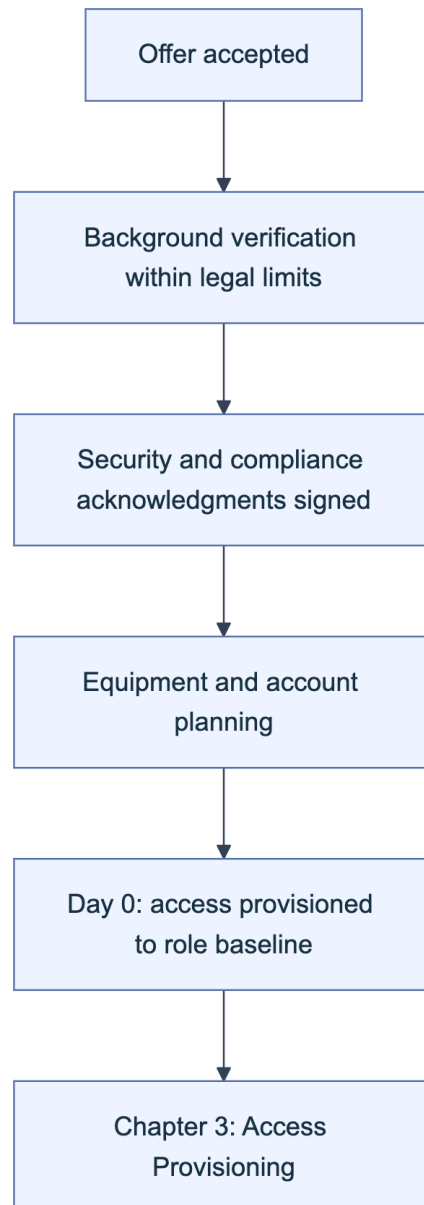


Figure 1. Pre-onboarding runs as a strict sequence. Each stage gates the next: an unverified identity should not reach the acknowledgment stage, and unsigned acknowledgments should not reach equipment and account provisioning.

2.1 Background and Verification (Within Legal Constraints)

Verification exists to answer one question before you extend any access: is the person you are about to onboard actually who your offer letter says they are? That question sounds trivial for an in-office hire and is not trivial at all for a remote Web3 team, where the interview, the reference check, and the equipment shipment may be the only points of contact before a laptop with production credentials leaves your control.

Run verification inside the legal framework that governs it. In the United States, the Fair Credit Reporting Act (FCRA) requires a standalone written disclosure that a consumer report may be used for an employment decision, the candidate's written authorization before you pull it, and, if

you plan to act on an adverse finding, a pre-adverse-action notice with a copy of the report followed by a post-adverse-action notice explaining the candidate's right to dispute it within 60 days ([FTC guidance for employers using consumer reports](#)). The EEOC's [joint guidance with the FTC](#) adds the discrimination-law layer: apply the same screening criteria to every candidate regardless of race, national origin, age, disability, or other protected status, and do not request medical or genetic information before a conditional offer. Outside the US, equivalents such as GDPR-derived data protection rules in the EU and UK constrain what you may collect and how long you may retain it. None of this is optional paperwork; skipping it exposes the organization to discrimination and privacy liability independent of any security benefit the check provides.

Verification also has to counter a documented, active threat specific to remote technical hiring. The FBI's Internet Crime Complaint Center (IC3) issued a public service announcement on October 18, 2023 describing how Democratic People's Republic of Korea (DPRK) operatives systematically obtain remote IT roles, including at crypto and Web3 firms, using stolen or fabricated identities ([FBI IC3 PSA 231018](#)). Part 1, Section 1.1 covers the incident data; the operational red flags belong here, at the point where you decide whether to extend an offer into a provisioned account.

Verification step	What it catches	Legal constraint to observe
Live video interview requiring government-issued ID on camera	Stolen-identity or stand-in candidates	Do not retain the ID image longer than needed to confirm identity
Independent reference check (call the number you find, not the one supplied)	Fabricated employment history	Apply consistently across all candidates to avoid disparate treatment
Third-party consumer report (criminal, credit where role-justified)	Undisclosed criminal history relevant to role risk	FCRA disclosure, authorization, and adverse-action process
Cross-check claimed location against interview timezone and language cues	Location misrepresentation, a recurring DPRK IT-worker indicator	Do not screen on national origin; screen on consistency of the candidate's own claims
Refusal to appear on video, or repeated last-minute reschedules	High-confidence fraud indicator per FBI IC3 PSA 231018	Document objectively (what happened), not speculatively (who you suspect)

The full DPRK IT-worker detection playbook, including ongoing monitoring after hire, is the Hiring, Remote Work, and Insider Threat Handbook's (05) domain. Treat this section as the gate before an offer converts to an account; treat Handbook 05 as the deeper reference when a red flag actually fires.

2.2 Security and Compliance Acknowledgments

Before you provision a single credential, the new hire should sign the documents that define what they are agreeing to protect and how. Treat these as a precondition for Chapter 3, not a parallel track that can lag behind it. An engineer who has infrastructure access but has not signed a confidentiality agreement has, from a legal standpoint, no enforceable obligation covering what they can now see.

The acknowledgment set for a Web3 organization is longer than a typical Web2 equivalent because token-related roles introduce securities and market-abuse exposure that most software companies never face.

Document	Purpose	Applies to
Non-disclosure agreement (NDA) and intellectual property (IP) assignment	Protects source code, keys, and unreleased protocol design; assigns work product to the company	All hires
Acceptable use policy (AUP)	Sets rules for company devices, accounts, and data, including personal-device (BYOD) boundaries	All hires
Code of conduct	Establishes behavioral and ethical baseline, including conflict-of-interest disclosure	All hires
Material non-public information (MNPI) and trading policy	Restricts trading the organization's token or related assets around unreleased information	Roles with token, governance, or exchange-listing visibility
Security and OpSec pledge	Commits the hire to the practices covered in Chapter 4 before they are trained on them	All hires, re-affirmed after training
Key custody agreement	Documents personal responsibility for any hardware wallet, seed material, or signer role issued	Treasury, deploy-key, and multisig roles only

Route these through an e-signature system that timestamps completion and stores an immutable copy, not a scanned PDF emailed back and forth. The completion record is what Section 5.2's audit trail actually checks against; an acknowledgment that exists only as an email attachment in someone's inbox is not verifiable months later when it matters.

2.3 Equipment and Account Planning

Equipment and account planning turns a hiring decision into a concrete list of what ships, what gets created, and in what order. Two failures recur here: shipping a company laptop to an address nobody verified, and provisioning accounts before verification and acknowledgments (Sections 2.1 and 2.2) are actually complete.

The shipping-address failure is not hypothetical. Christina Chapman, an Arizona resident, ran a residential “laptop farm” that received company-issued laptops on behalf of DPRK IT workers who had been fraudulently hired under stolen American identities at more than 300 US companies; the scheme moved over \$17 million to the North Korean government before Chapman was sentenced in 2025 to more than eight years in federal prison ([Christina Chapman case summary](#)). The FBI’s guidance is direct on the countermeasure: verify the shipping address against the identity documents collected during verification, and geolocate company laptops so that a device claimed to be in one country logging in from another triggers a review ([FBI IC3 PSA 231018](#)).

Decide company-issued versus personal-device (BYOD) policy by role risk before the hire’s start date, not on it. A company-issued laptop with full-disk encryption, endpoint detection and response (EDR), and mobile device management (MDM) enrollment should be the default for any role touching infrastructure, code, or treasury access; BYOD, if permitted at all, should be reserved for roles with no access to those three categories and should still require MDM enrollment for company email and communications tools.

Item	Standard hire	Treasury, deploy-key, or admin hire
Device	Company-issued, encrypted, EDR-enrolled	Company-issued, encrypted, EDR-enrolled; no exceptions
Shipping	Verified address matching ID on file	Verified address; consider in-person handoff or a bonded courier
Hardware security key	Optional at hire, required before privileged access	Required before any account is created
Account pre-provisioning	Baseline accounts created day before start	Nothing beyond email created until acknowledgments and training in Chapter 4 are complete
Initial device geofence	Not required	Enabled; alert on login from an unexpected country

Order matters: verify identity, collect signed acknowledgments, then ship equipment and create accounts, never the reverse. A device or credential sent ahead of verification is a device or credential you cannot easily claw back if verification later fails.

3. Access Provisioning

Access provisioning is where the four categories from Part 1, Section 1.2 (infrastructure, code, treasury, communications) become concrete grants tied to a specific person's role. Every grant in this chapter should trace to a role definition, not to an individual's ad hoc request, because a role definition is what makes offboarding in Part 3 mechanical instead of a memory exercise.

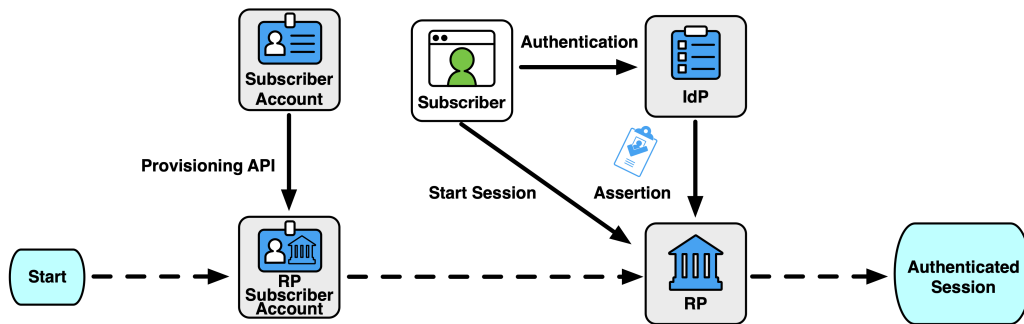


Figure. Pre-provisioning creates the relying-party account and its approved attributes before the first login. Use this pattern for privileged roles because an approver can constrain the account, verify its identifier, and record its expiry before any federation assertion can activate access. Source: *NIST SP 800-63C-4, Pre-Provisioning*, public domain (U.S. government work).

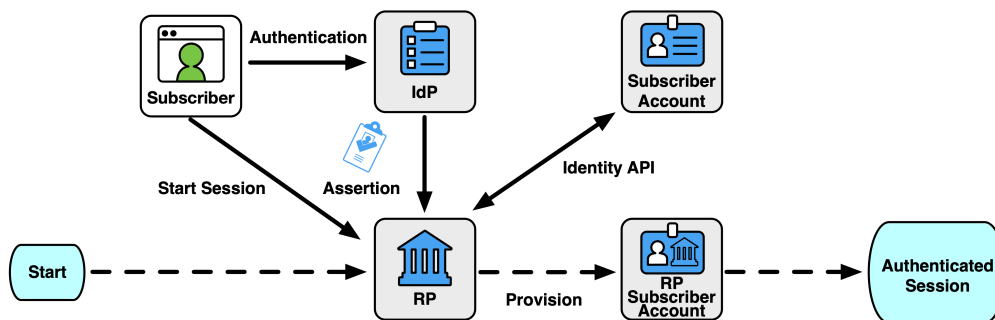


Figure. Just-in-time provisioning creates an account from the first valid federation assertion. It reduces ticket work for low-risk services, but it also means attribute mapping is the authorization boundary: a stale or over-broad group claim can instantiate privilege immediately across every relying party that trusts it. Source: *NIST SP 800-63C-4, Just-in-Time Provisioning*, public domain (U.S. government work).

3.1 Principle of Least Privilege by Role

Least privilege means a person's access matches what their current role requires and nothing more, a principle formalized across the security standards this handbook draws on, including *NIST SP 800-53's* Access Control family (AC-2, Account Management, and AC-6, Least Privilege) and *ISO/IEC 27001:2022 Annex A control 5.18, Access Rights*. The failure mode this guards against is exactly the privilege creep Part 1, Section 1.4 describes: access granted generously at hire, on the theory that it saves a future request, that nobody ever revisits.

Build role templates before you build individual grants. A role template specifies, for each of the four access categories, the default scope, the approver required for anything beyond that scope, and whether the category applies at all. A frontend engineer's template should show no default treasury access; a smart-contract deployer's template should show scoped, logged deploy-key access with no standing production database access. Where a role plausibly needs elevated access

some of the time (an on-call engineer needing production infrastructure access during a rotation) grant it as time-boxed, auto-expiring access tied to the on-call schedule, not as a standing grant that outlives the rotation, which is precisely the mechanism [NIST's identity and access management guidance](#) and Part 1's automated-versus-manual framing both point toward.

Role	Infrastructure	Code	Communications	Treasury
Frontend engineer	None	Read/write on frontend repos only	Standard workspace member	None
Backend/protocol engineer	Scoped to staging by default; production via time-boxed on-call grant	Read/write on assigned repos; no branch-protection bypass	Standard workspace member	None
Smart contract deployer	None beyond CI runner scope	Read/write on contracts repo; deploy-key use logged per deployment	Standard workspace member	Deploy-key holder only, not a treasury signer
Treasury or protocol multisig signer	None by default	None unless also an engineer	Standard workspace member	Signer slot, Section 3.4
Support or community manager	None	None	Elevated: public-channel moderation	None

Review every role template on a fixed cadence (quarterly is standard practice) and whenever the underlying system changes, so the template does not silently drift from what the role actually needs.

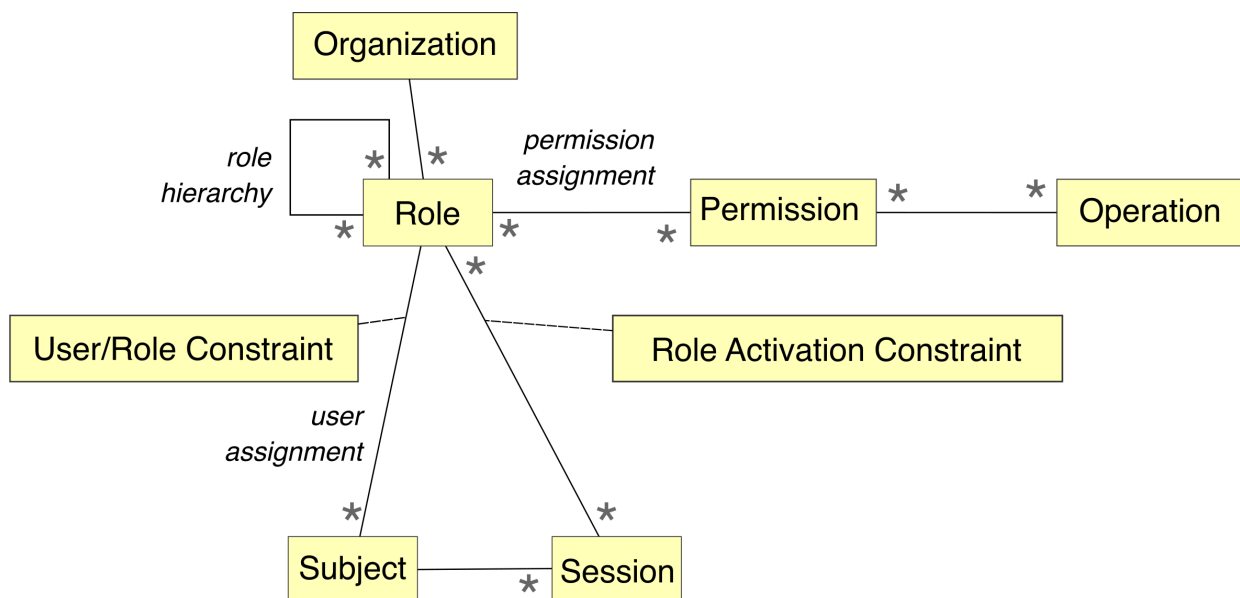


Figure. The role-based access control (RBAC) model behind the role template approach in this section: access flows from a Role to a Subject through a User Assignment, and from a Role to a Permission through a Permission Assignment, rather than being granted to an individual directly. Source: [Wikimedia Commons](#), CC0 1.0.

3.2 Infrastructure and Code Repository Access

Provision infrastructure and code access through group and role bindings tied to identity, never through individually shared credentials. Enforce single sign-on (SSO) with Security Assertion Markup Language (SAML) or OpenID Connect for every code hosting and cloud console login, so that revoking one identity-provider account (Part 3, Chapter 7) revokes access everywhere at once instead of requiring a system-by-system hunt.

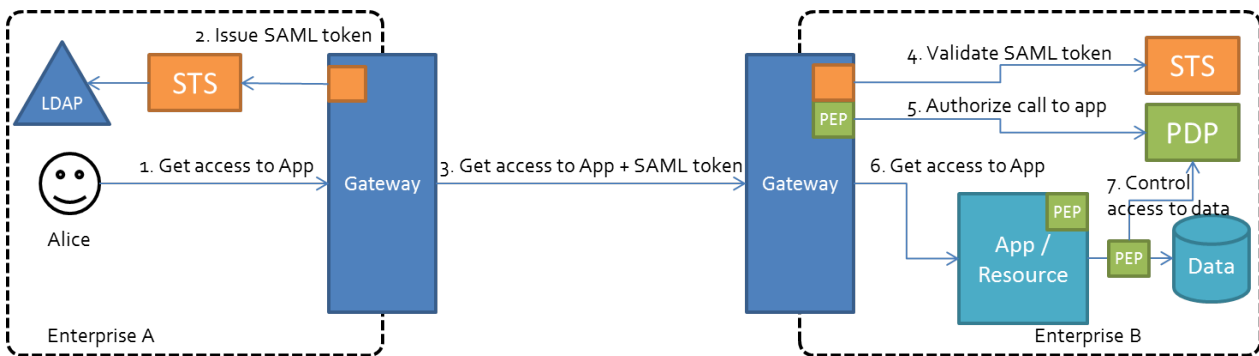


Figure. A federated SSO flow using SAML tokens issued by a security token service (STS) and checked against a policy decision point (PDP) before the request ever reaches the application; this is the mechanism that lets disabling one identity-provider account revoke access everywhere at once. Source: [Wikimedia Commons](#), CC BY-SA 4.0.

For code hosting, add a new engineer to a team, not to a repository directly, so their access is defined by team membership and disappears cleanly when they leave the team:

```
# Add a new hire to a scoped GitHub team rather than granting repo access directly
gh api orgs/ORG/teams/backend-engineers/memberships/NEW_HIRE_USERNAME \
  --method PUT \
  --field role='member'

# Confirm the team's repository permission level is least-privilege, not admin
gh api orgs/ORG/teams/backend-engineers/repos/ORG/protocol-contracts \
  --jq '.permissions'
```

Require branch protection on every repository that can affect production or deployable contracts: mandatory code review from someone other than the author, required status checks, and no direct pushes to the default branch, so that a single compromised or malicious account cannot merge unreviewed code.

For cloud infrastructure, write the new hire's permissions as a least-privilege policy scoped to what their role template specifies, not as a broad managed policy reused across roles:

```
{
  "Version": "2012-10-17",
  "Statement": [
    {
      "Effect": "Allow",
      "Action": ["logs:GetLogEvents", "logs:FilterLogEvents"],
      "Resource": "arn:aws:logs:*:ACCOUNT_ID:log-group:/staging/*"
    }
  ]
}
```

A staging-scoped read policy like this one gives a new backend engineer what their Section 3.1 template specifies on day one, with production access arriving later as a separate, time-boxed, logged grant rather than a standing permission bundled in at hire.

3.3 Communication and Collaboration Tools

Communications access (Slack or Discord, company email, ticketing, and any customer-support tooling) carries a different risk profile than infrastructure or code: it is lower blast-radius per grant but higher exposure to social engineering, because it is the channel an attacker uses to impersonate a colleague or vendor once they have a foothold. Provision it through the same SSO-backed identity as infrastructure and code, not through separately managed logins that survive an SSO deprovisioning event.

Default every new hire into a standard workspace membership with access to the channels their team needs and nothing that exposes organization-wide administrative functions. Elevate deliberately, not by default.

Tool	Default group at hire	Elevated group	Approver for elevation
Company email	Standard mailbox	Distribution list or alias ownership	Team lead
Slack or Discord	Team and all-hands channels	Workspace or server admin	Security lead
Domain registrar and DNS panel	No access	Named DNS administrators only	Infrastructure lead, logged change
Social media accounts	No access	Named brand or comms accounts	Marketing lead, dual-control posting where supported
Customer support platform	No access unless role-relevant	Ticket access scoped to support role	Support lead

Treat the domain registrar, DNS panel, and social media accounts as communications-category access with an unusually large blast radius: compromise of either can redirect users to a malicious front end or be used to push a fraudulent announcement, so keep the elevated group small and reviewed on the same cadence as treasury access in Section 3.4. The DNS-specific hardening for these systems is covered in the DNS and Hosting Security Handbook (02).

3.4 Wallet, Signing, and Treasury Access (If Applicable)

Treasury access is the category with no Web2 analog, and it is the one where onboarding mistakes convert directly into irreversible fund loss rather than a data-exposure incident. Not every hire needs this section; apply it only to roles your role template in Section 3.1 marks as treasury, deploy-key, or multisig-signer roles.

Most Web3 organizations hold treasury funds in a multi-signature (multisig) wallet requiring a threshold of signers, commonly built on **Safe** (formerly Gnosis Safe), which enforces that a transaction only executes once a defined number of the wallet's designated signers approve it on-chain, eliminating any single signer's unilateral control. Adding a new signer is itself a treasury operation and should go through the same threshold approval as any other multisig transaction, never through an off-chain administrative override.

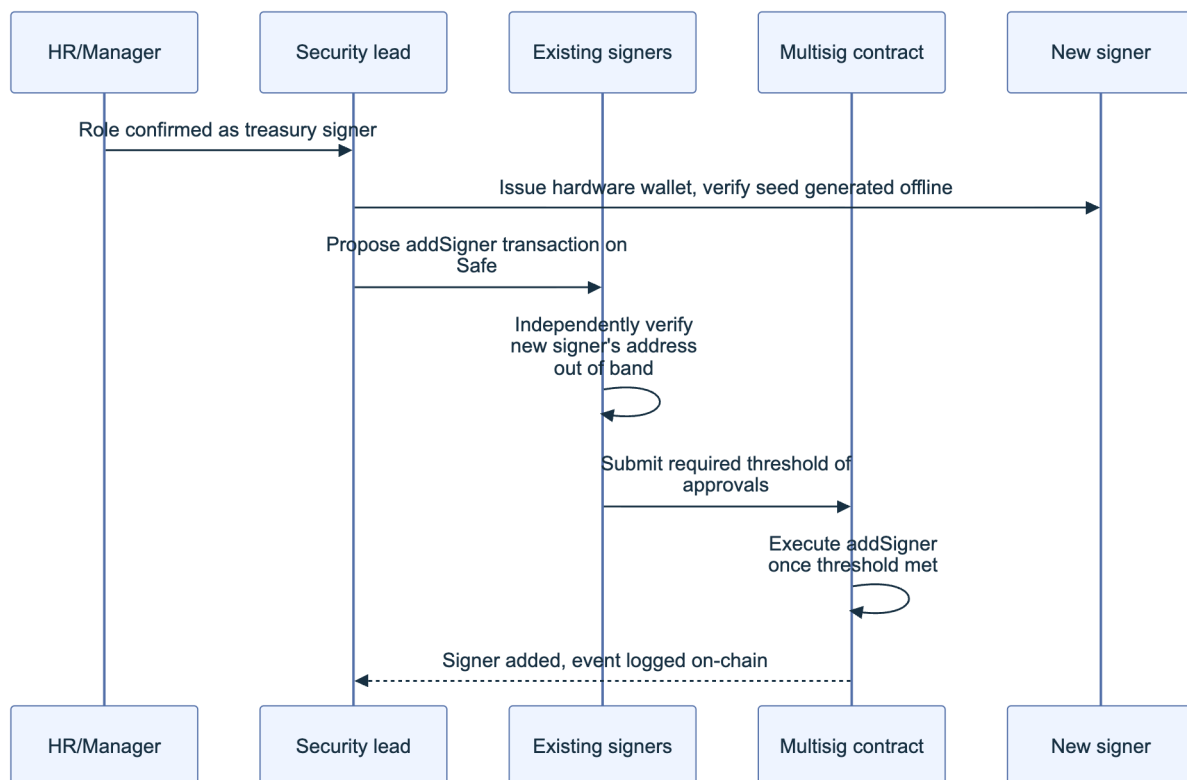


Figure 2. Adding a treasury signer as a threshold-gated on-chain operation. No single existing signer, and no HR or security action alone, can add a new signer.

The February 21, 2025 Bybit theft, in which attackers stole roughly \$1.4 to \$1.5 billion in Ethereum by compromising a developer machine at Safe's infrastructure provider and manipulating what legitimate signers saw and approved in their signing interface, is the clearest illustration of why the verification step in the diagram above matters: the FBI attributed the attack to DPRK-linked actors and the compromise succeeded because signers approved what their interface displayed without an independent, out-of-band check of the transaction's actual destination (**Bybit**

[hack summary](#)). Onboarding a new signer is the moment to establish the habit the rest of that signer's tenure depends on: verify a transaction's real content through a second channel, never trust the signing UI alone.

Issue a hardware wallet (a dedicated device that keeps private keys off any general-purpose computer) to every treasury or signer hire, generate seed material offline on that device, and never let seed phrases pass through email, chat, or a password manager not specifically designed for cryptographic key custody. Document the signer's onboarding in the key custody agreement from Section 2.2 before the multisig transaction in Figure 2 executes.

3.5 Documentation and Key Handoff Procedures

Every credential handed to a new hire, from a database password to a signer's hardware wallet, needs a handoff procedure that leaves no copy sitting in an insecure channel afterward. The [Last-Pass breaches disclosed in 2022](#) are the cautionary case for why this matters even for experienced staff: attackers compromised a senior DevOps engineer's home computer, installed a keystroke logger, and used the captured credentials to reach an internal vault holding further keys, ultimately exfiltrating customer password-vault data. The failure was not the initial account grant; it was that recovering from a personal-device compromise required unwinding access that had accumulated on a machine outside the company's own controls.

Follow the [OWASP Secrets Management Cheat Sheet](#)'s core rule for onboarding handoffs: never transmit a secret and its identifying context together, and never in plaintext over chat or email. A password and the username it unlocks should travel over different channels; a hardware wallet's seed phrase should never travel electronically at all.

- Provision infrastructure and application secrets through a secrets manager (HashiCorp Vault, AWS Secrets Manager, or equivalent) that issues the new hire short-lived, scoped credentials rather than a shared static password.
- Hand off any secret that cannot go through the secrets manager (an initial SSO password, a hardware key PIN) via a one-time, self-destructing link or an in-person exchange, never a persistent chat message.
- Require the new hire to rotate any initial credential on first use, so the handoff channel's exposure window closes immediately.
- Document, in the audit trail from Section 5.2, that each category of access was handed off and by what method, without recording the secret's value itself.
- For hardware wallets and multisig signer material, require in-person or courier handoff with chain-of-custody documentation, matching the treasury handling in Section 3.4.

4. Training and Awareness

Access without training is access an untrained person can misuse by accident as easily as an attacker can misuse it on purpose. This chapter makes training a gate, not a follow-up: the security and compliance acknowledgments in Section 2.2 commit a hire to practices they have not yet learned, and this chapter is where they actually learn them, before privileged access in Section 3.4 activates.

4.1 Security and OpSec Training

Structure onboarding security training as a short, mandatory curriculum completed before Day 0 access expands beyond the baseline role template, not as an annual module assigned sometime in the first quarter. Operational security (OpSec), the day-to-day discipline of protecting credentials, communications, and physical devices, is a distinct competency from general security awareness and deserves its own module for any Web3 hire; the Web3 Operational Security Handbook (11) is the full reference this module draws from.

Module	Core content	Gates
Phishing and social engineering recognition	Business email compromise, vendor impersonation, fake job-offer and recruiter-targeted attacks	Standard baseline access
Credential and secrets hygiene	Password manager use, hardware security key enrollment, secrets-manager basics	Any elevated infrastructure or code access
Wallet and signing OpSec	Transaction verification against the signing interface, seed phrase custody, hardware wallet use	Treasury or signer role activation
Physical and device security	Device encryption verification, screen-lock policy, secure disposal, travel guidance	Company equipment issuance
Incident reporting	Where and how to report, covered fully in Section 4.2	All roles

Issue a phishing-resistant authenticator, such as a FIDO2 hardware security key or a platform passkey, during this training rather than leaving multi-factor authentication (MFA) to a one-time-code app; the [FIDO Alliance](#) documents that passkeys and hardware keys use public-key cryptography bound to the legitimate site, which defeats the credential-relay phishing pages that a one-time code cannot.



Figure. FIDO2/U2F hardware security keys of the kind issued during onboarding training; binding authentication to a physical device is what defeats the credential-relay phishing pages a one-time code cannot stop. Source: [Wikimedia Commons](#), CC BY 2.0.

Require completion, verified by a quiz or a hands-on exercise, before the corresponding gate in the table above unlocks; a training assignment that nobody confirms was completed is not a control.

4.2 Incident Reporting and Escalation

A new hire needs to know, before their first week ends, exactly what to do the moment something looks wrong: a suspicious email, an unexpected transaction-signing prompt, a colleague asking for a credential over chat. The value of this knowledge decays the longer a genuine incident goes unreported, so make the reporting path short, memorable, and blame-free for a false alarm.

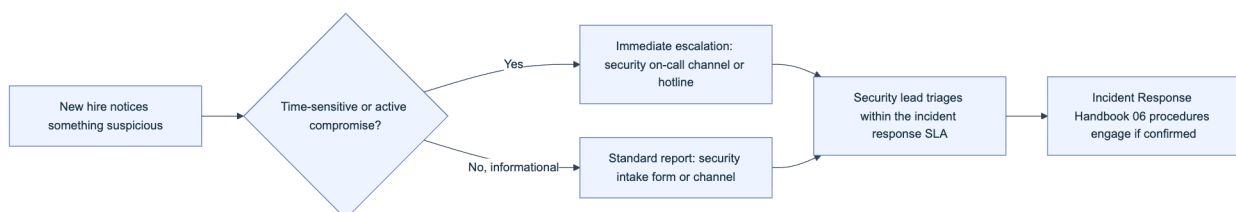


Figure 3. The reporting decision a new hire needs to internalize during onboarding: escalate immediately for anything time-sensitive, and use the standard channel otherwise. Both paths reach the same triage owner.

Give every new hire, in writing, the specific channel name or contact for security on-call, the security intake form or address for non-urgent reports, and an explicit statement that reporting a false positive carries no penalty. Tie this directly into the fake-interview and impersonation social-engineering pattern documented in the [OWASP Web3 Attack Vectors Top 15](#) (WA05, fake interview and video-call social engineering, and WA08, phishing and general social engineering): a new hire is a fresh, unfamiliar face to the rest of the organization and is disproportionately likely to be the target of an impersonation attempt during their first weeks, precisely because attackers know internal recognition of who belongs where is weakest then. Once a genuine incident is confirmed, ownership transfers to the procedures in the Incident Response Handbook (06); this section's job is only to get the report to that owner quickly.

4.3 Ongoing Awareness

Onboarding training establishes a baseline; ongoing awareness keeps it from decaying as the threat landscape moves and the new hire's memory of Day 1 training fades. Treat this as a recurring program with a fixed cadence, not a one-time event that onboarding closes out.

Run unannounced phishing simulations on a regular cadence (quarterly is a reasonable default for most teams) and treat a click as a training trigger, not a disciplinary one; the goal is behavior change, and punitive responses to simulation failures reliably make employees stop reporting real incidents out of fear. Pair simulations with periodic tabletop exercises specific to Web3 risk, such as a simulated fraudulent signing request or a fake urgent wire transfer from an impersonated executive, so the team practices the Section 4.2 reporting path under realistic pressure rather than encountering it for the first time during a genuine incident. [Verizon's Data Breach Investigations Report](#) consistently finds that the human element, phishing and social engineering among them, remains a leading factor across breaches even as attackers diversify toward software-vulnerability exploitation, which is the argument for treating awareness as a maintained control rather than a completed task.

Refresh the curriculum itself whenever a new attack pattern becomes relevant (a new fake-interview technique, a new wallet-drainer approach) and re-communicate material changes to the entire team, not only new hires, since an outdated shared understanding of the threat landscape is itself a gap an attacker can exploit.

5. Checklist and Documentation

Everything in Chapters 2 through 4 needs to leave a record, both so onboarding can be verified as complete and so Part 3's offboarding process has a known baseline of what was granted to compare a departure against.

5.1 Onboarding Checklist Template

Use a single tracked checklist per hire that spans every chapter in this part, with a named owner and a completion timestamp for each item, not a mental list distributed across HR, IT, and the hiring manager's separate inboxes.

Phase	Task	Owner	Complete before
Pre-onboarding	Identity and background verification complete (2.1)	HR/Security	Offer finalized
Pre-onboarding	Security and compliance acknowledgments signed (2.2)	HR	Account creation
Pre-onboarding	Equipment shipped to verified address, accounts pre-provisioned to baseline (2.3)	IT	Day 0
Access provisioning	Role template applied for infrastructure, code, communications (3.1-3.3)	IT/Security	Day 0
Access provisioning	Treasury or signer access provisioned if role requires it (3.4)	Security lead	Signer role activation
Access provisioning	All secrets handed off via approved method, none left in chat or email (3.5)	IT	Day 0
Training	Security and OpSec training modules completed (4.1)	Security	Elevated access activation

Phase	Task	Owner	Complete before
Training	Incident reporting channel confirmed understood (4.2)	Manager	End of week 1
Documentation	Checklist reviewed and signed off by someone other than the provisioner (5.2)	Security lead	End of week 1

A printable version of this template, formatted for direct use in a runbook, is [Appendix B](#).

5.2 Audit Trail and Review

A completed checklist is only as trustworthy as the evidence behind it. Log every provisioning action with enough detail to reconstruct, months later, exactly what was granted, by whom, and on what authority, matching the process-evidence expectations of frameworks such as SOC 2 (System and Organization Controls 2) Trust Services Criteria CC6 (logical access controls), which most Web3 organizations handling customer or partner data will eventually need to demonstrate compliance against.

Log field	Why it matters
Requestor and approver identity	Confirms the grant followed the role template's required approval, not an informal request
Timestamp of grant and of role-template version used	Lets a later reviewer confirm the grant matched the policy in effect at the time
System and specific scope granted	Makes the grant auditable against the least-privilege table in Section 3.1
Acknowledgment and training completion timestamps	Confirms Section 2.2 and Chapter 4 gates were actually satisfied, not assumed
Reviewer and review date	Distinct from the provisioner; closes the loop with independent verification

Review the audit trail on a fixed cadence, quarterly at minimum and immediately after any security incident, and specifically look for grants that exceed their role template, accounts still pending an incomplete acknowledgment past a reasonable deadline, and any provisioning action with no recorded approver. Retain the trail for the period your compliance obligations require (SOC 2 audits typically expect at least twelve months of evidence, and Sarbanes-Oxley Act, SOX, or Payment Card Industry Data Security Standard, PCI DSS, scope where applicable extends that further) and store it somewhere the people it tracks cannot themselves alter, so the record remains meaningful evidence rather than a document the audited party also controls.

Key controls for Part 2

- Verify identity and run background checks within FCRA and EEOC constraints before any account or equipment is provisioned, screening for the documented DPRK IT-worker indicators in FBI IC3 PSA 231018.
- Sequence pre-onboarding strictly: verification, then signed acknowledgments, then equipment and accounts. Never ship a device or create an account ahead of a completed identity check.
- Provision every access grant from a least-privilege role template covering all four Part 1 categories, with treasury and multisig access added only through threshold-gated on-chain operations, never an off-chain override.

- Hand off every secret through an approved channel that leaves no persistent copy, and require rotation on first use.
- Gate elevated and treasury access behind completed security and OpSec training, not behind a scheduling convenience.
- Log every provisioning action with requestor, approver, scope, and timestamp, and review that trail on a fixed cadence independent of the people who did the provisioning.

Part III: Offboarding

Offboarding is where lifecycle security gets tested against a clock: every extra hour an account stays live is an hour a departing insider, or whoever compromised their credentials on the way out, can use it. Web3 organizations carry higher offboarding stakes than a typical SaaS company, because the credentials behind a departing engineer can include a multisignature (multisig) signer key or live deploy authority over a contract holding user funds, not just a dashboard login. This Part walks the full sequence: what triggers a departure, what has to be revoked and in what order, how keys get recovered and rotated, and the audit trail and legal coordination that close the departure out cleanly.

6. Offboarding Triggers and Timing

The trigger event decides everything downstream: who gets notified, how fast access dies, and whether the departure follows the calm choreography of a two-week notice or the urgency of a same-day lockout. Misclassify the trigger and either legitimate handover work gets disrupted, or a hostile actor keeps a working credential for days longer than it should exist.

6.1 Planned and Unplanned Departures

A resignation with standard notice, a retirement, a contract reaching its agreed end date, or a scheduled role change all count as planned departures: the organization knows the date in advance and can sequence revocation around a handover. Termination for cause, a confidential reduction in force, sudden incapacity or death, and the discovery of an active insider compromise are unplanned: the organization does not control the timeline and often does not want the departing person to know the exact moment access disappears.

Web3 firms face an unplanned-trigger scenario that most companies do not: the discovery that an already-hired, currently active worker is compromised or fraudulent. Coinbase's May 2025 disclosure is the sharpest recent example. Cybercriminals bribed a small number of overseas customer-support contractors to exfiltrate account data on a subset of customers; Coinbase reported that under 1% of monthly active users were affected, no passwords or private keys were

exposed, the criminals demanded a \$20 million ransom that Coinbase refused, and the company estimated remediation and customer reimbursement costs at up to \$400 million while offering its own \$20 million bounty for information on the attackers ([Coinbase 2025 data breach](#), [Wikipedia summary of public disclosures](#)). The response there was not a scheduled offboarding: it was immediate, targeted revocation of specific contractor accounts the moment compromise was confirmed, run by security rather than HR. The same emergency-trigger logic applies to a worker later identified as part of a fraudulent employment scheme, such as the pattern of Democratic People's Republic of Korea (DPRK) nationals obtaining remote IT and engineering roles under false identities; that hiring-side threat is covered in depth in the Hiring, Remote Work, and Insider Threat Handbook (05), but the offboarding response to a confirmed case follows the unplanned, emergency path described here.

Trigger	Category	Typical lead time	Primary owner
Resignation with notice	Planned	2 to 4 weeks	HR (Human Resources) and manager
Retirement	Planned	Weeks to months	HR
Contract or engagement end	Planned	Known in advance	Procurement and HR
Termination for cause	Unplanned	Same day	Security, HR, Legal
Reduction in force	Unplanned (scheduled but confidential)	Hours	HR and Security
Insider compromise or fraud confirmed	Unplanned, emergency	Minutes to hours	Security
Sudden incapacity or death	Unplanned	Immediate, sensitive handling	HR and Legal

6.2 Immediate vs. Phased Revocation

Immediate revocation cuts every credential the moment the trigger fires: same instant for a security incident, same day for a termination for cause. Phased revocation stages access removal across a notice period, holding lower-risk access (read-only tools, calendar, general email) open for handover while pulling high-blast-radius access first regardless of how amicable the departure is. Even a fully planned, friendly resignation should treat production infrastructure, deploy credentials, and wallet or multisig authority as immediate-revocation items on the last working day; phasing is appropriate for handover-supporting access, not for anything that can move funds or ship code.

The control basis for this timing comes from [NIST Special Publication 800-53 Revision 5](#), whose Personnel Security family control PS-4 (Personnel Termination) requires disabling system access within an organization-defined time period on the date of termination and retrieving all security-related organizational property, coordinated with the Access Control family's AC-2 (Account Management), which governs disabling, removing, and reviewing accounts when the individual's

need for access ends. Most mature Web3 organizations interpret “organization-defined time period” as same day for anything unplanned and same day for the sensitive tier even on planned departures.

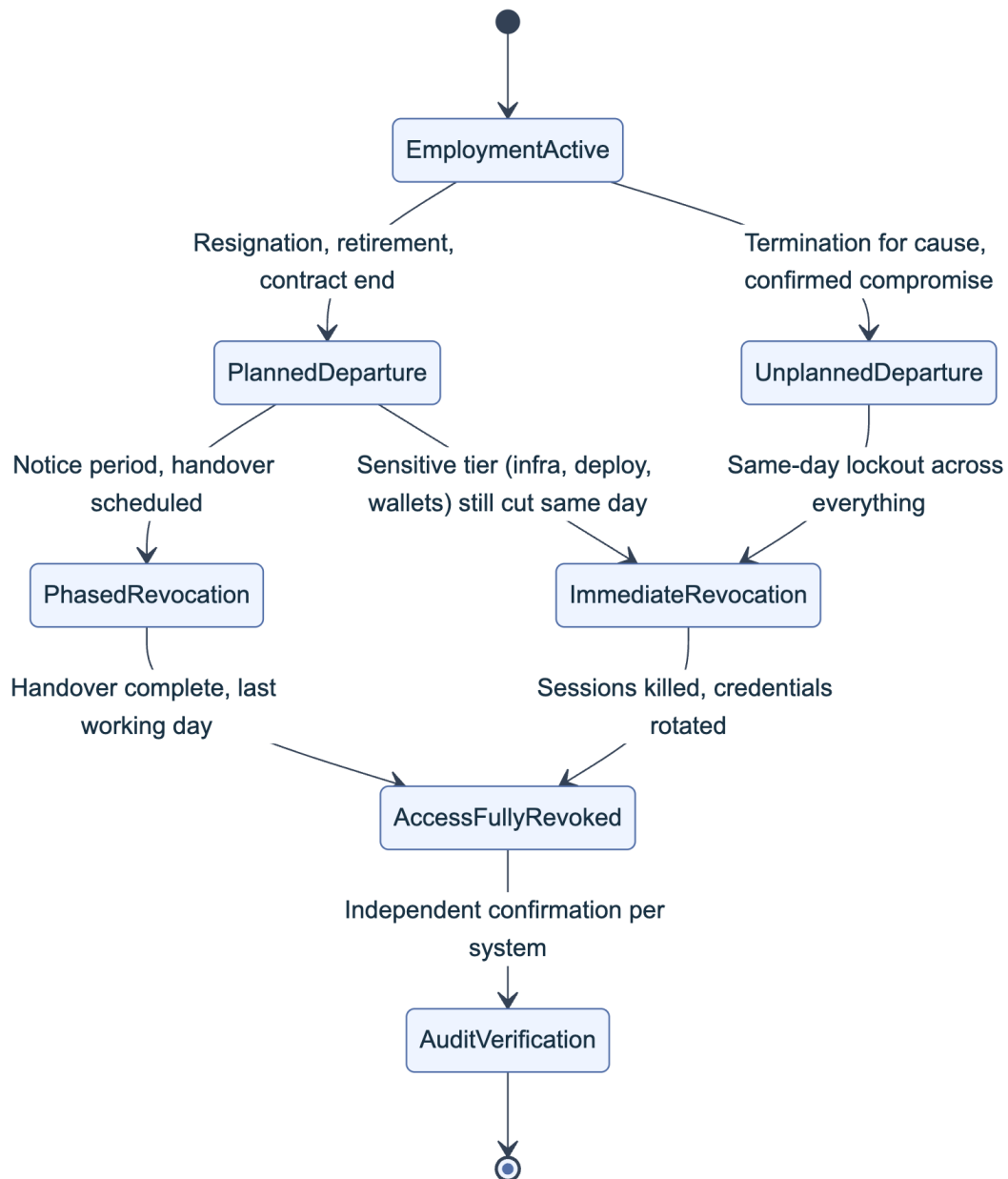


Figure 6. Departure trigger flows into a revocation model. Even a planned departure routes its highest-risk access through the immediate path.

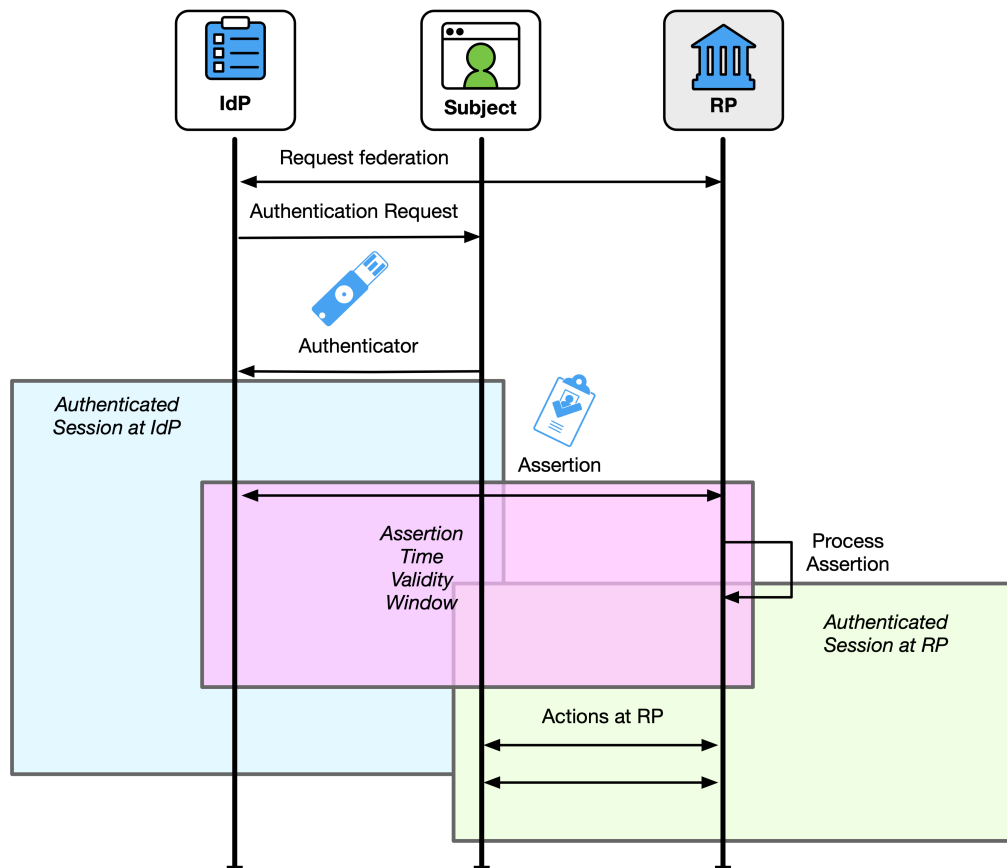


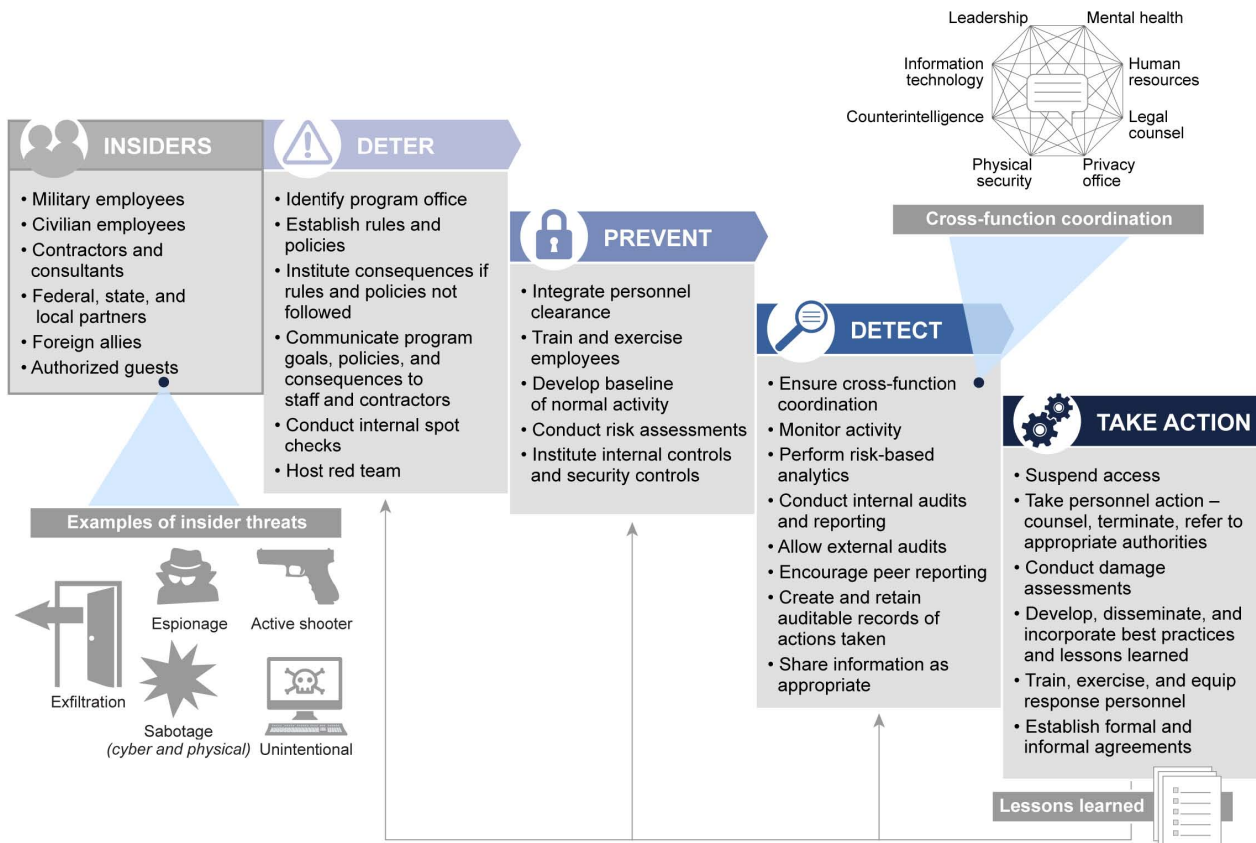
Figure. Federation creates at least two independently expiring sessions: one at the identity provider and one at the relying party. Disabling the central account does not prove every relying-party session has ended, so offboarding must pair IdP revocation with downstream session termination or a deliberately short relying-party timeout. Source: *NIST SP 800-63C-4, Session Management*, public domain (U.S. government work).

6.3 Risk of Orphaned Accounts and Unrevoked Credentials

An account left active after its owner leaves is not a passive risk, it is an attack primitive with a name. *MITRE ATT&CK technique T1078, Valid Accounts*, documents adversaries specifically seeking out “inactive accounts: for example, those belonging to individuals who are no longer part of an organization,” because, as the technique page notes, “the original account user will not be present to identify any anomalous activity.” An orphaned account is worse than a stolen one from a detection standpoint: nobody is watching it, nobody expects to see a login notification from it, and it often carries whatever standing privilege it had on the departing person’s last working day, unreduced.

The risk runs in both directions during the offboarding window itself. Beyond an outsider later abusing a forgotten credential, a departing insider with advance knowledge of their own termination date has a narrow window to act against the organization before access is cut: locking out administrators, deleting resources, or revoking others’ access. *MITRE ATT&CK T1531, Account Access Removal*, catalogs exactly this pattern, noting that adversaries (a category that includes malicious insiders) disable accounts, change passwords, and remove administrative permissions to disrupt availability, and that the technique “cannot be easily mitigated with preventive controls

since it is based on the abuse of system features” already granted to the account. The defense is timing discipline, not a single control: classify the trigger correctly (6.1), choose the revocation model before the person is notified (6.2), and never leave a gap between notification and lockout that a departing insider could exploit. Password resets alone are insufficient against either direction of this risk, because a live session token, an active API key, or an already-cached cloud credential survives a password change; revocation has to invalidate sessions and rotate tokens, not just the login.



Source: GAO analysis of Department of Defense (DOD), U.S. government, and private-sector guidance and reports. | GAO-15-544

Figure. A government-analyzed framework for structuring an insider-threat program end to end; the “Take Action” phase, suspend access, take personnel action, conduct damage assessments, is the same terminal step this chapter’s revocation timing exists to make fast and complete. Source: U.S. Government Accountability Office, GAO-15-544, via Wikimedia Commons, public domain (U.S. government work).

7. Access Revocation

With the trigger classified, revocation has to reach every system that trusted the departing person, not only the ones IT remembers to check. The fan-out below is the shape every offboarding ticket should follow.

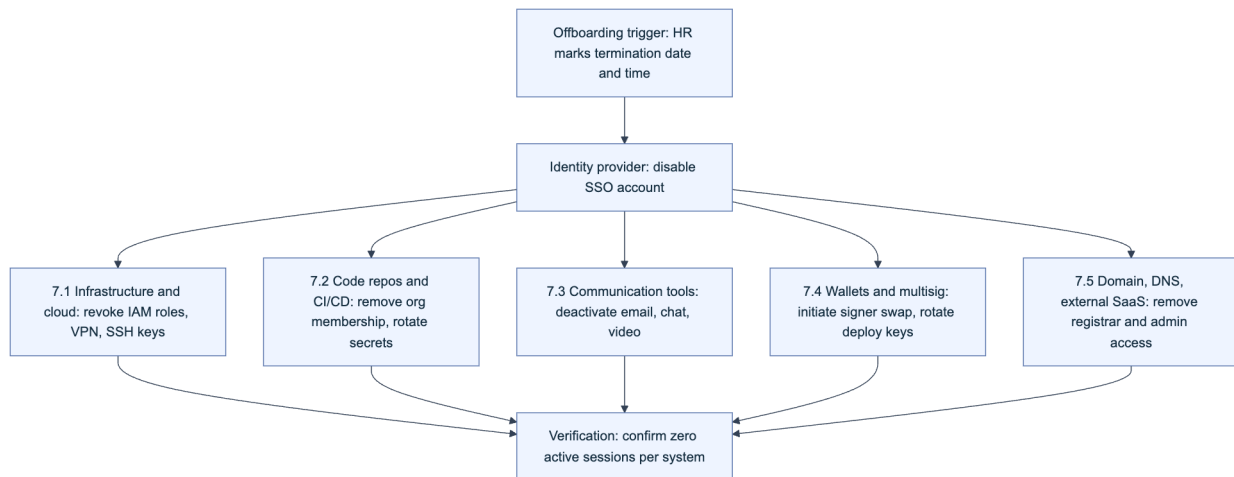


Figure 7. A single trigger fans out across five independent domains. Each has its own credential model, so disabling the identity provider (IdP) account alone does not close all five.

7.1 Infrastructure and Cloud Access

Cloud consoles (AWS, Google Cloud, Azure) grant access through Identity and Access Management (IAM) users, roles, and long-lived access keys that a single sign-on (SSO) logout does not automatically invalidate; an already-issued cloud session token or access key stays valid until it is explicitly revoked or expires on its own schedule. Revocation here means disabling the IAM user or federated role binding, deleting any access keys issued directly to that identity, revoking VPN certificates and Secure Shell (SSH) keys added to bastion hosts or servers, removing the person from Kubernetes role-based access control (RBAC) bindings, and rotating any break-glass or emergency-access credential they knew. Treat every credential type separately: a disabled SSO account with a still-valid AWS access key is not offboarded, it is half-offboarded.

- Disable or delete the IAM user and any role-assumption trust relationships naming them individually
- Revoke and delete access keys, not just deactivate the console password
- Remove SSH public keys from `authorized_keys` on every host they could reach, including jump boxes
- Pull VPN client certificates and any static VPN credentials
- Audit and rotate shared break-glass credentials they had access to

7.2 Code Repositories and CI/CD

Removing someone from a GitHub organization revokes their access to private repositories and private forks, though GitHub notes the person may retain local copies of code they already downloaded, and membership records are retained for reinstatement for three months after removal ([GitHub documentation, removing a member from your organization](#)). Critically, org removal by itself does not revoke personal access tokens (PAT), SSH keys, or OAuth application grants tied to that individual's personal account; for organizations using SCIM-based provisioning or GitHub Enterprise Managed Users, removal must also flow through the identity provider to

fully take effect, per the same documentation. Continuous integration and continuous delivery (CI/CD) pipelines add a second layer: rotate any secret the person could read from Actions secrets, deploy keys, or signing keys, since a removed collaborator's local clone or cached credential could otherwise still authenticate a pipeline run.

```
# Remove a departing engineer from the GitHub organization
gh api -X DELETE "/orgs/ACME/members/departing-user"

# Audit org-scoped personal access tokens still associated with them
gh api "/orgs/ACME/personal-access-tokens" --paginate \
  | jq '.[] | select(.owner.login=="departing-user")'

# Rotate any CI/CD secret they could have read or exported during their tenure
gh secret set DEPLOY_KEY --org ACME --body "$(cat new_deploy_key)"
```

7.3 Communication and Collaboration

Email, chat (Slack, Discord, Telegram, all common in Web3 teams that maintain a public community presence alongside internal channels), video conferencing, ticketing systems, and shared password managers all need explicit deactivation, and email is the one channel where immediate deletion is usually wrong: set a defined forwarding or legal-hold window instead, since active conversations and legal discovery obligations often outlive the employee. Discord and Telegram carry a blind spot the other tools don't: bot tokens and server-owner or admin roles are frequently issued to a single named individual rather than a service account, and that bot token keeps working with full server privileges until someone explicitly rotates it, regardless of whether the human's personal account is removed from the server. Inventory every bot token, webhook, and integration credential the departing person could have generated, not just their personal login.

7.4 Wallets, Keys, and Multisig Roles

This is the domain most SaaS offboarding checklists never anticipate and Web3 organizations cannot skip. Safe (formerly Gnosis Safe), the most widely deployed smart-contract multisig, manages owners through four functions defined in its `OwnerManager` contract: `addOwnerWithThreshold`, `removeOwner`, `swapOwner`, and `changeThreshold`, all of which carry an `authorized` modifier requiring the call to be a self-executed Safe transaction, meaning it must itself be signed by enough existing owners to meet the current threshold ([Safe smart contracts](#), `OwnerManager.sol`). That has a direct operational consequence: removing a departing signer is itself a multisig action that needs the cooperation of the remaining signers, which means signer offboarding has to be planned and, wherever possible, executed before the last working day, not attempted afterward when the departing signer's cooperation can no longer be assumed and the remaining signers may sit right at the threshold. Prefer `swapOwner`, which atomically replaces the departing owner with a new one in a single transaction, over a separate remove-then-add sequence that leaves the Safe at a reduced effective owner count in between.

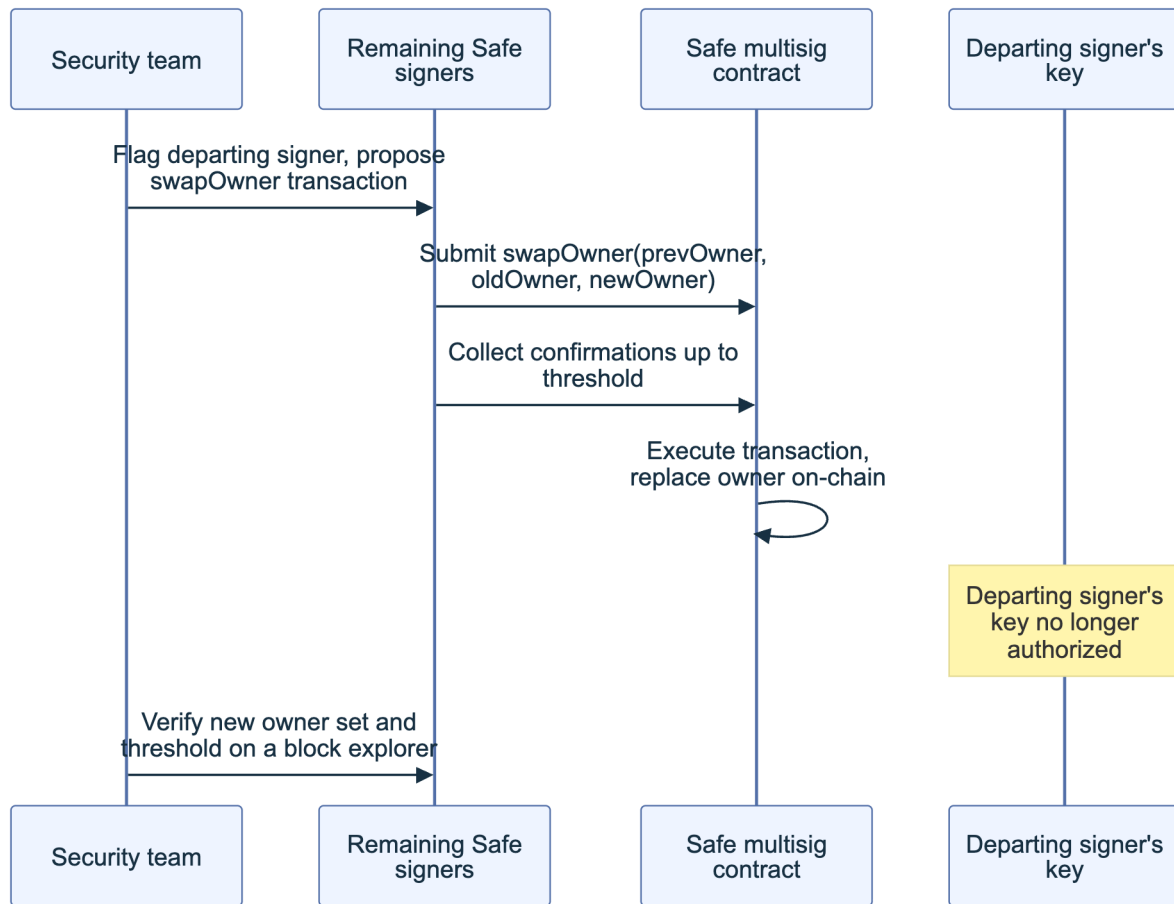


Figure 8. Multisig signer offboarding is an on-chain transaction the remaining signers must execute, not a settings toggle in an admin panel.

Beyond multisig seats, cover single-signature deploy keys and hot wallets used in deployment scripts (rotate to a freshly generated keypair and sweep any residual balance) and personal hardware wallets used to co-sign treasury transactions (physically retrieve the device where possible; where retrieval is not feasible, treat the key as compromised and rotate the Safe owner regardless, since an externally owned account key that may still be in someone's possession cannot be partially trusted).

7.5 Domain, DNS, and External Accounts

Domain registrar and Domain Name System (DNS) provider consoles, content delivery network (CDN) dashboards, cloud email administration (Google Workspace or Microsoft 365 admin roles), payment processor and analytics dashboards, and social media or Discord server ownership all carry standing admin power that a general SSO deprovisioning sweep can easily miss, because these accounts are often created directly with the vendor rather than federated through the corporate IdP. Registrar and DNS access is the highest-blast-radius item on this list: whoever controls DNS for a live dApp's front-end domain controls where every user's browser goes, a risk the CDN and Front-End Supply Chain Handbook (01) and the DNS and Hosting Security Hand-

book (02) both treat as a primary attack surface. Maintain a living inventory, a spreadsheet at minimum or an identity governance and administration (IGA) tool at scale, mapping every external account to a named owner, so revocation does not depend on someone remembering which contractor signed up for which SaaS product eighteen months earlier.

8. Asset and Key Recovery

Revocation removes authorization; recovery closes out the physical and cryptographic material that authorization was attached to. Skipping this step leaves working keys sitting on a device nobody is tracking.

8.1 Company Devices and Credentials

Laptops, phones, hardware security keys, hardware wallets, access badges, and any printed material containing sensitive information all need a defined return path with a deadline, not an open-ended “whenever is convenient.” Where a device cannot be retrieved promptly, mobile device management (MDM) tooling should remote-wipe it before physical return completes, and any device being reissued to a new hire should be sanitized according to [NIST Special Publication 800-88 Revision 1](#), which defines media sanitization as rendering “access to target data on the media infeasible for a given level of effort” and provides technique guidance for clearing, purging, and destroying different media types.

Asset	Action	Owner
Laptop / desktop	Remote wipe if not returned same day; sanitize per NIST SP 800-88 before reissue	IT
Phone (company-owned)	Remote wipe, deregister from MDM	IT
Hardware security key (YubiKey)	Deregister from every service, physically collect or disable	Security
Hardware wallet	Physically collect; if uncollectable, rotate any Safe or account it co-signed	Security
Access badge	Deactivate in physical access system same day	Facilities/Security
Printed sensitive material	Confirm return or witnessed destruction	Manager

8.2 Key Rotation Where Necessary

Revoking and rotating are different actions with different costs, and conflating them either wastes effort or leaves risk on the table. Revocation removes authorization for a credential that never left recoverable form in the departing person’s hands: a short-lived cloud session token, or a key

bound to hardware that never exports its private material. Rotation issues entirely new key material because the old key may have been copied: a software wallet's private key, a Key Management Service (KMS) export the person downloaded, or a plaintext secret sitting in a local `.env` file they had read access to. The decision rule is conservative by design: rotate whenever there is any doubt about whether the departing person could have exported the key, and reserve simple revocation for credentials that were architecturally incapable of leaving their original, access-controlled location. For a Safe multisig, `swapOwner` (Section 7.4) is the rotation mechanism; for a single-signature deploy or admin key, mandate full rotation to a new address and migrated authority whenever there is doubt, since an externally owned account's private key offers no equivalent of a partial-trust state the way a multisig's threshold does.

8.3 Documentation and Handover

A departure that removes access without transferring knowledge trades one risk for another: the account is closed, but nobody left on the team knows how the disaster-recovery Safe was configured, where a split seed phrase's other shares live, or which runbook step the departing engineer always did manually and never wrote down. Handover documentation should update the infrastructure and code ownership records, reassign open pull requests and issues, update `README` and `CODEOWNERS` maintainer lists, and remove the departing person from any secrets-escrow or key-custodian role, replacing them with a named successor before the last working day rather than after. Treat this as a security deliverable, not a courtesy: undocumented, single-person operational knowledge is itself an availability and recovery risk once that person is gone.

9. Checklist and Documentation

A checklist only earns its name if it is actually run and someone signs off that each line happened; an unexecuted template is a false sense of coverage.

9.1 Offboarding Checklist Template

Structure the template by phase rather than by system, so the same document works whether the trigger is planned or a same-day emergency; unplanned departures simply compress every phase into hours instead of weeks.

Phase	Action	Owner	Deadline	Verified
Trigger confirmed	Classify planned vs. unplanned, select revocation model	HR / Security	T0	
Notification	Notify IT, Security, Legal, and the person's manager	HR	T0 + 1 hour	
Sensitive-tier lockout	Cut infra, deploy, wallet, and multisig access (Sections 7.1, 7.2, 7.4)	Security	T0 (same day, always)	
Standard-tier lockout	Disable SSO, email, chat, ticketing (Sections 7.1, 7.3)	IT	T0 to last day	
External accounts	Revoke registrar, DNS, external SaaS admin (Section 7.5)	Security	Last day	
Asset return	Collect devices, badges, hardware keys (Section 8.1)	IT / Facilities	Last day + 3 days	
Key rotation	Rotate any key the person could have exported (Section 8.2)	Security	Last day + 3 days	
Handover	Reassign ownership, update runbooks (Section 8.3)	Manager	Last day + 5 days	
Legal close-out	Reaffirm NDA, confirm data return (Chapter 10)	Legal / HR	Last day + 5 days	
Audit	Independent verification across every system (Section 9.2)	Security lead	T0 + 30 days	

9.2 Verification and Audit

Revocation that nobody independently checks is a claim, not a control, and audit frameworks treat it that way: a System and Organization Controls 2 (SOC 2) auditor will routinely sample terminated employees and ask for timestamped proof of prompt access removal, not just a completed checklist. Build that evidence in as you go rather than reconstructing it later: an identity provider's deprovisioning event log, generated automatically when using the System for Cross-domain Identity Management (SCIM) protocol to synchronize account state across connected systems ([RFC 7644](#), [SCIM Protocol](#)), gives a machine-generated timestamp that a manually filled checklist cell cannot match. Follow the initial revocation with an independent confirmation, ideally by someone other than whoever executed it, 24 to 72 hours after the trigger, checking for zero active sessions, zero valid API keys or tokens, and zero remaining multisig ownership, and fold that same person's access status into the organization's next periodic access review as a second, later check.

10. Legal and HR Coordination

Offboarding is not purely a technical exercise: it closes a legal relationship, and that closure needs Legal and HR at the table alongside Security, not informed after the fact.

10.1 Confidentiality and Non-Disclosure

The exit conversation should explicitly reaffirm the confidentiality and non-disclosure agreement (NDA) and any intellectual property assignment terms the person signed at hiring, remind them which obligations survive departure (trade secrets, unreleased roadmap detail, pending token generation events), and, for Web3 organizations specifically, cover any restrictions on trading the organization's token, or a closely related project's token, while still in possession of material non-public information, along with vesting and lock-up terms that continue after employment ends. Enforceability of non-disclosure and non-compete language varies substantially by jurisdiction and by worker classification (employee versus contractor), so this section is a coordination checkpoint for qualified legal counsel to confirm what is actually enforceable where the departing person is based, not a security-team template to apply uniformly.

10.2 Return of Assets and Data

Physical asset return is covered in Section 8.1; this section covers data, including data the organization holds about the departing person and data the person holds that belongs to the organization: a personal wallet used for company transactions, a personal GitHub account holding an org-granted personal access token, or personal cloud storage synced with company documents. In jurisdictions covered by the General Data Protection Regulation (GDPR), Article 17's right to erasure requires an organization to delete personal data once it is "no longer necessary in relation to the purposes for which [it was] collected," but that obligation coexists with separate retention duties, such as payroll, tax, or access-log records tied to a legal or compliance requirement, so a departing employee's erasure request does not automatically mean total deletion ([GDPR Article 17](#)). Set the data retention schedule for personnel and access records jointly with Legal and HR before the organization's first departure, so the boundary between "must delete" and "must retain" is a documented policy decision rather than an improvised judgment call made under the pressure of an actual exit.

Key controls for Part 3

- Classify every departure as planned or unplanned before choosing a revocation model, and route the sensitive tier (infrastructure, deploy, wallets, multisig) through immediate same-day revocation regardless of which model applies.

- Revoke sessions and tokens, not just passwords; a disabled SSO login does not invalidate an already-issued cloud access key or session token.
- Plan multisig signer removal before the last working day: `swapOwner` requires the cooperation of the remaining signers and cannot be executed unilaterally after the departing signer is gone.
- Rotate, don't just revoke, any key the departing person could plausibly have exported or copied.
- Maintain a living inventory of external accounts (registrar, DNS, SaaS admin) mapped to a named owner, so revocation never depends on institutional memory.
- Verify revocation independently, 24 to 72 hours out, and keep timestamped evidence (SCIM deprovisioning logs, screenshots, exported audit trails) for SOC 2 and similar audits.
- Coordinate confidentiality reaffirmation, data return, and retention decisions with Legal and HR as a standing process, not an ad hoc conversation at each departure.

Part IV: Special Considerations

Parts 1 through 3 covered the general lifecycle: how a person enters, how they are provisioned, and how they leave. Some roles and working arrangements break that general model and need their own controls, because the person is not an employee, is never in the same room as the rest of the team, or holds a key that can move the treasury. This part covers contractors, remote and distributed teams, treasury and admin roles, multisig signer lifecycle, and what happens when a key role has no backup.

11. Contractors and Short-Term Roles

Web3 organizations run on contractors more than most industries realize. Solidity auditors, protocol-specific developers, community managers, and exchange-integration partners are frequently engaged for a single sprint or a single audit cycle, and DAOs in particular often have no full-time headcount at all, only a rotating set of contributors paid per contribution. That structure creates a lifecycle gap: contractors are commonly provisioned with the same urgency as employees, because the work cannot wait, but offboarded with far less urgency, because nobody owns “contractor offboarding” the way HR owns employee termination. An engagement that was supposed to run four weeks quietly becomes six months, and the repository access, Slack membership, and Safe delegate role granted on day one are still live long after the invoice was paid.

This gap is precisely what the Democratic People’s Republic of Korea (DPRK) remote-worker scheme is built to exploit. Since at least 2022, DPRK intelligence services (principally the Reconnaissance General Bureau) have trained operatives to apply for remote software engineering, blockchain development, and IT contractor roles on platforms such as LinkedIn and Upwork, using stolen identities, AI-enhanced photos, and in several documented cases real-time deepfake video to pass interviews ([Wikipedia: North Korean remote worker infiltration scheme](#)). Once hired, the operative asks for the company laptop to be shipped to a US-based “facilitator” who runs a laptop farm, so that traffic appears domestic while the actual work is done from North Korea or a China-based safehouse. The FBI, State Department, and Treasury have issued joint public warnings on this specific pattern, OFAC sanctioned two individuals and four DPRK front

companies in January 2025 for operating these placement schemes, and the Department of Justice indicted 14 North Korean nationals in December 2024 for generating an estimated \$88 million through fraudulent IT contracting over six years, with a further indictment in January 2025 covering two US-based facilitators who placed operatives in more than 60 companies. Security-awareness vendor KnowBe4 disclosed publicly that it unknowingly hired one such operative for a Principal Software Engineer role in mid-2024; malware began loading from the newly shipped Mac workstation within minutes of delivery, and the company’s SOC contained the device the same evening after EDR alerts fired ([KnowBe4, “How a North Korean Fake IT Worker Tried to Infiltrate Us”](#)). The OWASP Web3 Attack Vectors Top 15 formalizes this as its own category, [WA15: Nation-State Infiltration via Fake Hiring and Malicious OSS Contributions](#), precisely because crypto-native companies are disproportionately targeted: the payout is directly in cryptocurrency, and remote-first hiring norms make the identity-verification gap wider than at a traditional enterprise.

Treat every contractor engagement as a scoped, time-boxed grant rather than a lighter version of employment. Fix an end date in the engagement letter or statement of work and set access expiry to match it in whatever identity provider or SSO gates repository, Slack, and wallet access; do not rely on a human remembering to revoke. Verify identity for any contractor who will touch code, infrastructure, or funds with the same rigor as an employee: government ID checked over a live video call (not a photo upload), a real-time conversation where the interviewer can ask unscripted follow-up questions, and payment to a bank account or verified payment processor rather than to a wallet address supplied on day one with no other proof of banking identity. Refuse requests to ship equipment to an address that does not match the verified identity, refuse requests to route pay through a third party “for tax reasons,” and treat a contractor who declines camera-on interviews or avoids synchronous calls entirely as a finding requiring escalation, not an eccentricity.

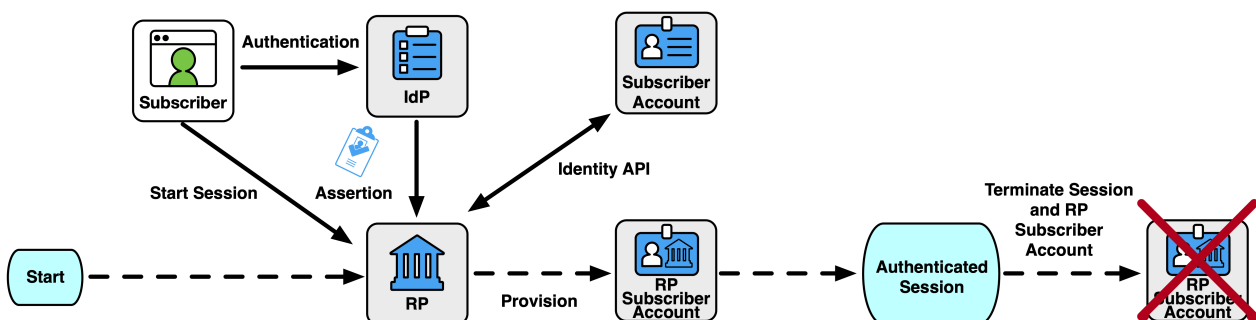


Figure. Ephemeral provisioning is the safest default for one-off reviewers and short engagements that do not need persistent state: the relying party consumes the validated assertion without creating a durable local account. Where the application supports it, this removes an orphaned-account class instead of merely promising to clean it up later. Source: [NIST SP 800-63C-4, Ephemeral Provisioning](#), public domain (U.S. government work).

Signal	Why it matters	Response
Candidate insists on text-only interviews or frequent audio/video glitches during calls	Common cover for real-time voice-changing or deepfake tooling	Require at least one unscheduled, camera-on call before extending an offer
Requested equipment ship-to address differs from stated residence, or is a mail-forwarding service	Laptop-farm pattern used to route hardware to a facilitator	Verify address against ID; decline mismatches
Multiple simultaneous contracts with overlapping working hours across companies	Consistent with a single operative servicing several placements at once	Cross-check references' contactability independently, not via numbers the candidate supplies
Insists on cryptocurrency-only payment with no invoicing or tax documentation	Avoids the banking-identity trail that a legitimate contractor would generate	Route payment through a verified payroll/contractor platform, not a bare wallet address
Github/portfolio history is thin, recently created, or forked with minimal original commits	Fabricated résumé pattern seen across documented DPRK IT worker cases	Weight technical screening over portfolio claims; verify claimed past employers directly

12. Remote and Distributed Teams

Most Web3 protocols are remote-first by default, often distributed across a dozen time zones with no shared office and no in-person onboarding day. That model has real advantages, but it removes a control that traditional organizations rely on without ever naming it: the physical presence check. A new hire who shows up to an office, badges in, and sits next to a colleague has passed an identity check nobody wrote down. A remote hire who exists only as a Zoom window and a Slack handle has passed no such check, and the entire trust chain rests on whatever verification happened during recruiting.

The March 2022 Ronin Network bridge hack is the reference incident for how this gap gets weaponized against a specific engineer rather than against the company broadly. Attackers attributed to North Korea's Lazarus Group approached a senior Axie Infinity/Sky Mavis engineer through a fake recruiting process on LinkedIn, ultimately sending a PDF disguised as a generous job offer; opening it deployed spyware that compromised the engineer's system and, from there, enough validator infrastructure for the attacker to forge withdrawal signatures and drain roughly \$625 million in ETH and USDC, discovered only six days later ([Wikipedia: Ronin Network](#); FBI attribution, April 2022). The lure was not aimed at a low-privilege contractor; it was aimed precisely at the person with the most access, using the same recruiting channels a legitimate offer would use. The OWASP Web3 Attack Vectors Top 15 captures this pattern as [WA05: Fake Inter-](#)

view and Video Call Social Engineering, and it recurs constantly: fake recruiters, fake “technical assessment” repositories laced with malicious dependencies, and fake video-call clients that request a codec plugin install before the call can start.

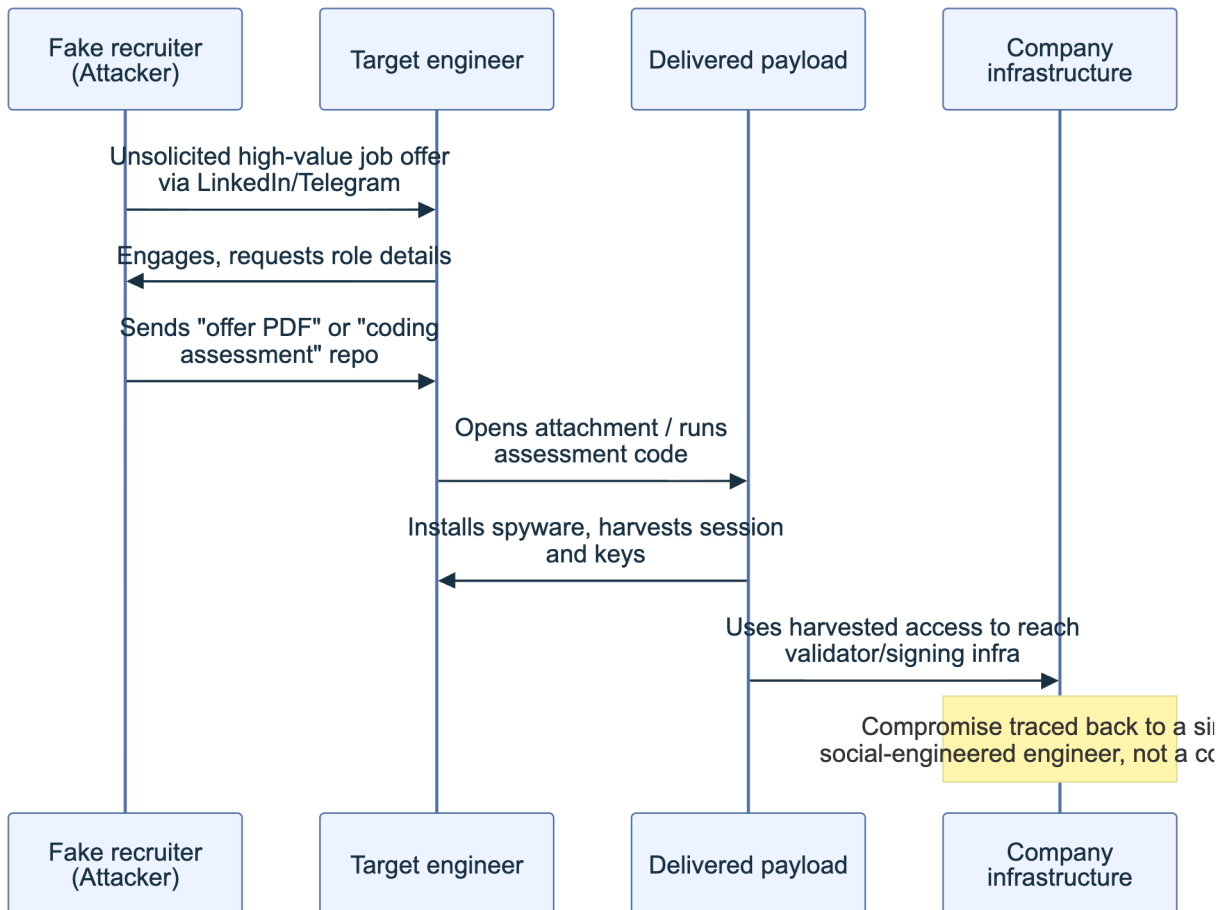


Figure 1. The fake-recruiter pattern behind the Ronin bridge compromise: the attack targets the person, not the protocol, and the payload rides in through a channel (recruiting) that security tooling rarely inspects.

Distributed teams need controls that substitute for the physical presence check they never had. Verify a new remote hire’s identity with a live, camera-on video call and government ID at the start of the relationship, and repeat spot checks are reasonable for high-privilege roles, not just at hire. Issue company-managed, EDR-monitored hardware rather than allowing personal devices for anyone who will touch signing keys, deploy credentials, or admin panels, because a company-owned device is the only place a security team can actually detect the Ronin-style payload landing. Train every engineer, not only recruiters, that unsolicited job offers, “urgent” coding assessments from unfamiliar recruiters, and requests to install unfamiliar software to join a call are a named attack pattern with a name they should recognize (WA05), not a generic phishing reminder. Route all recruiting-adjacent contact for current staff, including “market research” calls and unsolicited advisory offers, through a channel the security team can see, because the entry point for a distributed-team compromise is social before it is technical.

13. High-Risk Roles (Treasury, Deploy Keys, Admin)

Not every role carries the same blast radius if it is compromised. A support agent's account, if hijacked, produces an information-disclosure incident; a treasury signer's key, if hijacked, produces a headline. This chapter narrows from the general onboarding and offboarding process in Parts 2 and 3 to the specific controls that apply once a role touches funds, deploy credentials, or protocol admin functions directly.

13.1 Treasury Operations: Classification, Registration, Enhanced Controls

Start by classifying every wallet and key the organization holds, because a control set applied uniformly to a \$500 gas-refill hot wallet and a \$50 million treasury cold multisig is either too weak for the treasury or too heavy for the hot wallet. Register each wallet in a single inventory that names its purpose, its custody tier, its signers, and its threshold, and review that inventory on a fixed cadence rather than only when someone remembers to. This registration step matters independently of the technical controls: incident responders and auditors repeatedly find organizations that cannot answer “how many wallets do we control” on demand, which means they also cannot answer “which of these needs revocation” during an active incident.

Tier	Example	Custody model	Enhanced controls
Operational	Gas refill, testnet faucet	Hot wallet, single signer	Hard cap on balance; auto-refill from treasury, never manual top-up above cap
Working capital	Market-maker inventory, exchange deposit wallet	Hot or warm wallet, 2-of-3 multisig	Daily balance cap tied to trading volume; alerting on any balance above threshold
Treasury reserve	Protocol treasury, DAO reserve	Cold multisig, hardware-signed, 4-of-7 or higher	Time-locked large withdrawals; geographically and organizationally distributed signers; no single employer relationship spans a majority of signers
Emergency/pause authority	Circuit-breaker admin key	Cold multisig or timelocked contract role	Separate signer set from treasury reserve; documented, rehearsed activation runbook

Enhanced controls scale with tier. Treasury reserve wallets should never share a signer majority with any other wallet tier, so that compromise of the operational hot wallet's signer set cannot cascade. Signer diversity matters as much as signer count: a 4-of-7 multisig where five signers are employees of the same company reporting to the same executive is not meaningfully more resistant to coercion or collusion than a 3-of-5 with genuinely independent signers, a point directly relevant to the wrench-attack and insider-collusion categories in the OWASP Web3 Attack Vectors Top 15 ([WA11: Wrench Attacks and Physical Coercion](#); [WA12: Insider Threats and Collusive Abuse](#)).

13.2 Transaction Verification Protocols for Large Transfers

The single most consequential lesson from the crypto industry's largest hack to date is that multisig thresholds do not protect you if every signer trusts the same compromised interface. On 21 February 2025, Bybit's cold Safe{Wallet} multisig was used to route roughly \$1.5 billion in ETH to an attacker-controlled address; forensic analysis by Elliptic and Arkham Intelligence attributed the theft to the Lazarus Group, and the FBI specifically named TraderTraitor actors. The attack did not break the multisig's cryptography. It compromised infrastructure at the third-party Safe{Wallet} provider so that the transaction data the signers reviewed in their browser did not match the transaction their hardware wallets actually signed: the signers saw a routine transfer and approved what was, in the underlying calldata, a contract upgrade that handed control of the cold wallet to the attacker ([Bybit hack summary and attribution](#)). This is blind signing in its purest form, cataloged as [WA01: Multisig Hijacking](#) in the OWASP Web3 Attack Vectors Top 15, and it is why "we require N signatures" is not, by itself, a transaction-verification protocol.

A transfer above a defined threshold should never rely on the signing interface's rendered summary alone. Require every signer to independently decode and confirm the raw calldata (not merely the wallet UI's description of it) against the intended recipient, method, and amount, using a hardware wallet's own display or an independent decoder, before signing. Verify the destination address through a channel separate from the one that requested the transfer, a callback to a known phone number or a pre-shared verification code, never a reply on the same thread that raised the request, which mirrors the out-of-band verification already required for business email compromise defense in the Incident Response Handbook (06). Tier the required verification to the transfer size so that routine flows are not bottlenecked while large flows get real scrutiny.

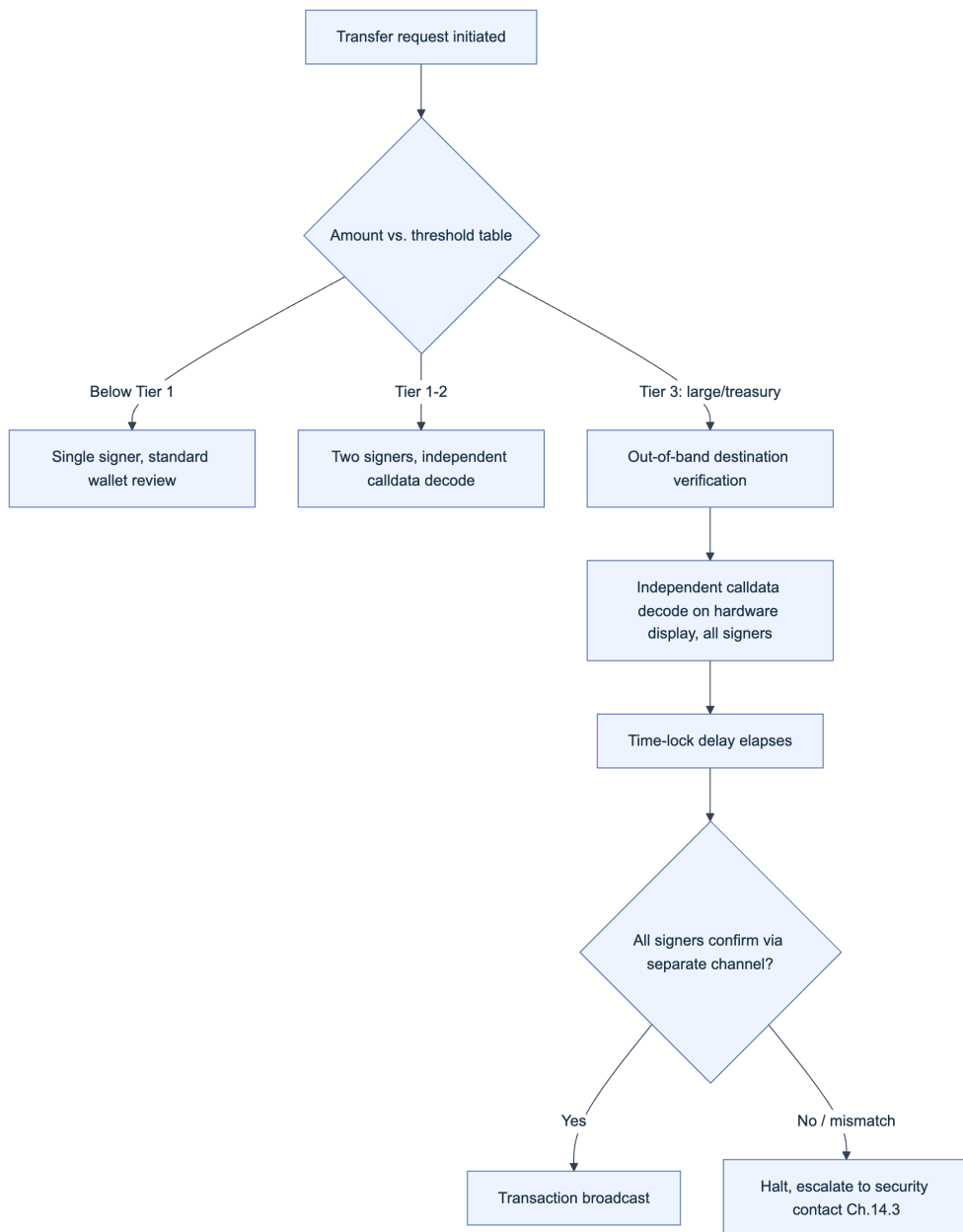


Figure 2. Tiered transaction verification. Higher tiers add out-of-band checks and calldata decoding precisely because interface-level trust is what Bybit's attackers exploited, not the multisig math.

Set a mandatory time-lock delay on withdrawals above the treasury reserve threshold, long enough that a compromised signing session can be detected and halted before funds move, and staff an on-call rotation that can act on that alert within the delay window. Log every transaction verification step, including who performed the out-of-band check and what channel they used, so that a post-incident review can determine whether the protocol was followed or bypassed.

14. Multisig and Protocol Signer Lifecycle

Multisig signers are a distinct role from “employee with a wallet.” A signer’s authority persists across employment changes unless someone actively removes it from the contract, which means the multisig lifecycle needs its own onboarding, offboarding, and incident channel layered on top of the general processes in Parts 2 and 3.

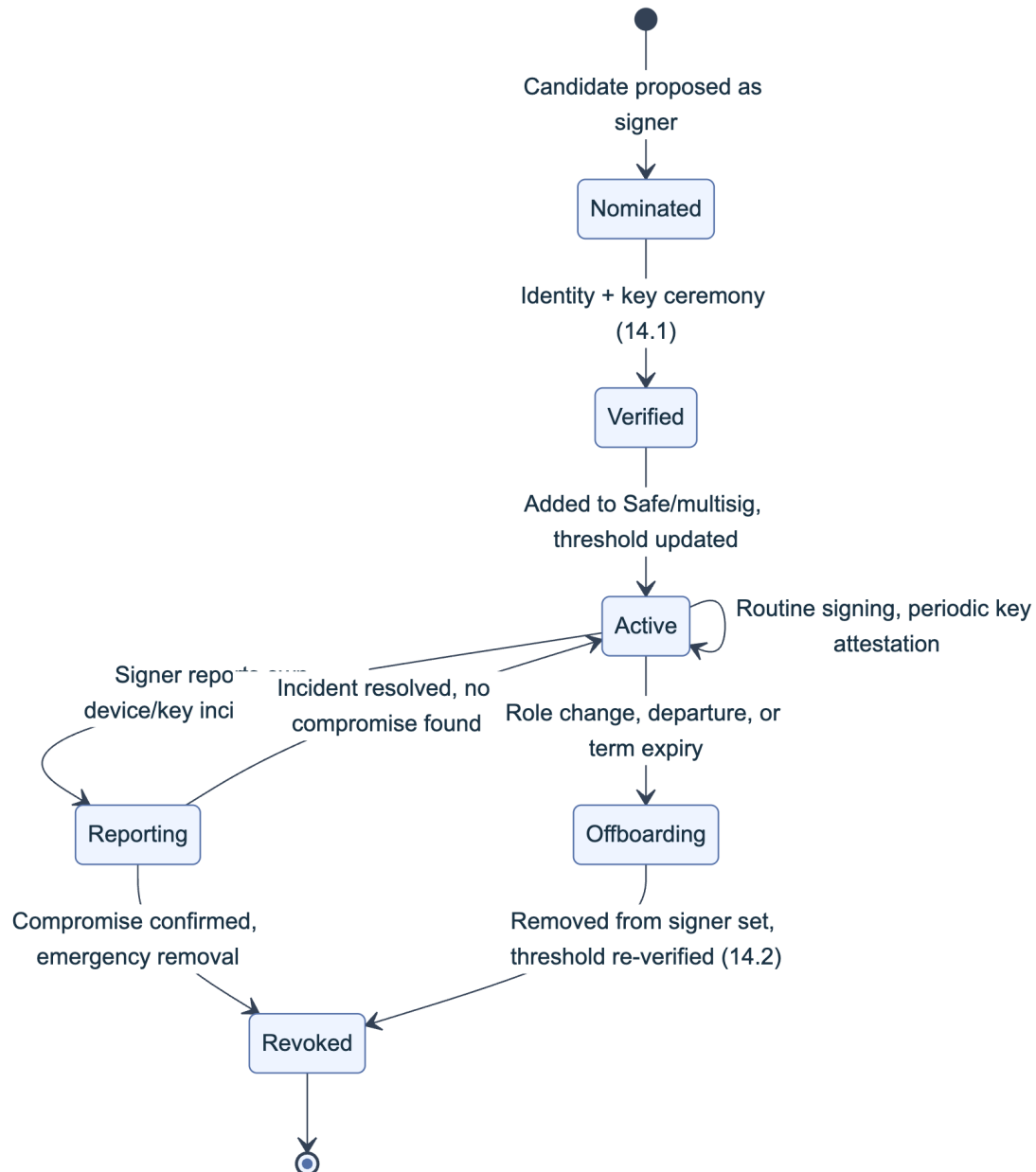


Figure 3. The signer lifecycle runs in parallel with, not as a subset of, general employee offboarding: a departing employee’s signer role must be revoked on-chain, which HR-driven account deprovisioning never touches.

14.1 Joining a Multisig: Verification and Onboarding

Adding a signer is an on-chain, generally irreversible-without-consensus action, so verify before you add rather than trusting and revoking later. Confirm the candidate's identity through the same live, camera-on process used for high-risk hires (Chapter 12), independent of any prior working relationship, because an insider threat or a hijacked account inside the organization can request a signer addition just as convincingly as a legitimate one. Run a documented key ceremony: the candidate generates their signing key on a hardware wallet the organization did not ship them blind (verify the device's authenticity and firmware against the vendor's attestation), the public key or address is read aloud or shared over a verified channel and cross-checked against what gets submitted on-chain, and at least one other current signer witnesses the ceremony live. Add the signer and immediately update the documented threshold and signer registry from Section 13.1, including the new signer's backup and recovery contact for succession purposes (Chapter 15).

Signer onboarding checklist

- ☐ Candidate identity verified via live video call and government ID
- ☐ Hardware signing device sourced and verified independent of shipment from an unverified party
- ☐ Key ceremony conducted with at least one witnessing signer, address cross-checked over a separate channel
- ☐ New signer added on-chain; threshold re-confirmed to match the documented policy
- ☐ Signer registry and treasury inventory (13.1) updated with the new signer and their backup contact
- ☐ New signer briefed on the transaction verification protocol (13.2) and the incident reporting channel (14.3)
- ☐ New signer's security contact and succession backup recorded (Chapter 15)

14.2 Offboarding as Signer: Key and Role Handback

Signer offboarding is the step general employee offboarding (Part 3) is most likely to miss, because it requires an on-chain transaction, not a checkbox in an identity provider. Treat every departure, role change, or contract expiry that involves a signer as triggering its own workflow: remove the departing signer from the multisig and re-verify the threshold before, not after, any other offboarding step that might tip them off, mirroring the immediate-versus-phased revocation guidance in Chapter 6. Do not merely lower the threshold to compensate for a departing signer without first confirming the remaining signer set still meets the diversity requirement from Section 13.1; a threshold reduction that leaves four of five signers reporting to one manager quietly degrades the control the tier was designed to provide.

Require the departing signer to physically surrender or verifiably destroy any organization-issued hardware signing device, and if the device may have held a shared seed or backup material (it should not, per the succession guidance in Chapter 15), rotate anything derived from it. Confirm removal on-chain with a transaction hash logged in the signer registry, and have a remaining signer independently verify the new signer set and threshold rather than trusting the initiator's report. Where the departure is adversarial or the reason for departure itself raises suspicion, treat it as a security incident under Chapter 14.3 rather than a routine offboarding, and consider an out-of-cycle rotation of the multisig itself (deploying a new Safe and migrating funds) if there is any reason to believe the departing signer's key material was ever exposed beyond their control.

14.3 Incident Reporting and Security Contact for Signers

Every signer needs a named, always-available channel to report a suspected key or device compromise, and that channel needs to be faster and more direct than the general employee incident-reporting path in Part 2, because a delay of hours between a signer suspecting compromise and the organization acting on it is the difference between a near-miss and a Bybit-scale loss. Publish a dedicated security contact (a rotating on-call, not a single person who might be unreachable) that any signer can reach by phone or a pre-agreed secure channel at any hour, and rehearse the response: freeze pending transactions, verify the suspect signer's recent signing activity against what they recall approving, and be prepared to execute an emergency signer removal or full multisig migration under the pause authority defined in Section 13.1.

Signers should report proactively, not only after confirmed compromise: a lost or briefly unattended hardware device, a phishing attempt that specifically referenced their signer role, or an unfamiliar transaction request routed through an unusual channel are all reportable events under a no-blame policy, because a signer who hesitates to report a near-miss out of fear of scrutiny is exactly the gap an attacker like the Bybit intrusion team is counting on. Log every report, resolved or not, in the same registry used for treasury inventory and signer onboarding, so that a pattern of near-misses against a specific signer becomes visible before it becomes an incident.

15. Succession and Backup for Key Roles

A role with no backup is a single point of failure dressed up as an organizational chart entry, and Web3's history has two clean demonstrations of what happens when that single point of failure is also the only person who can move funds. In December 2018, QuadrigaCX founder and CEO Gerald Cotten died unexpectedly while traveling in India; he was the sole holder of the passwords to the exchange's cold wallets, and roughly C\$250 million (about US\$190 million) owed to some 115,000 customers became permanently inaccessible, a loss later found by Canadian regulators to be entangled with Cotten's own prior fraud rather than pure accident, but the succession failure was real regardless of motive: no other person in the organization could access the funds ([Wikipedia: QuadrigaCX](#)). In 2023, the cross-chain bridge protocol Multichain collapsed after its founder, known publicly as "Zhaojun," was reportedly detained by Chinese authorities; because operational control of the protocol's MPC (multi-party computation) key infrastructure was concentrated around him, hundreds of millions of dollars in user funds across multiple chains were frozen with no other party able to authorize withdrawals, and the protocol never recovered.

Both incidents share the same root cause with different triggers: a founder or executive, not a technical vulnerability. Succession planning for key roles is therefore a security control, not an HR nicety, and it belongs in this handbook alongside multisig thresholds and access revocation because it addresses the same underlying risk, a single actor whose absence (voluntary, coerced, or fatal) can freeze or lose funds. NIST's guidance on contingency and continuity planning establishes the general principle that any function critical to operations needs a documented backup and a tested recovery path ([NIST SP 800-34 Rev. 1, Contingency Planning Guide for Federal Information Systems](#)); applied to Web3, that principle means no individual signer, deploy-key holder, or admin-role owner should be a true single point of failure, regardless of how much the organization trusts them personally.

Succession planning matrix

Key role	Single point of failure risk	Required backup mechanism	Test cadence
Multisig signer	Low if threshold and diversity (13.1) are correct	N-of-M design itself is the backup; no individual signer holds sole authority	Quarterly threshold and diversity review
Deploy key / contract owner (single-key patterns)	High if not migrated to multisig or timelock	Migrate to a Safe or timelocked governance contract; document emergency multisig re-key procedure	Annual, or immediately on any admin change
MPC or threshold-signature custody operator	High if operational knowledge is concentrated in one engineer or executive	Cross-train at least two additional operators; store recovery shares per the custody provider's documented multi-party procedure, never with one person	Semiannual recovery drill

Key role	Single point of failure risk	Required backup mechanism	Test cadence
Protocol admin/pause authority	High if held by a single wallet regardless of who controls it	Move to a multisig or council with defined quorum before mainnet launch, not after an incident	Documented in the emergency runbook (13.1)
Exchange or platform account owner (domain, cloud root, registrar)	High, and frequently overlooked because it is "just an account"	Documented secondary admin with independent MFA, escrowed per Handbook 02's domain and registrar guidance	Annual access review

Build succession into onboarding for every key role from day one rather than retrofitting it after a departure: no signer should be added (14.1) without a documented backup contact and no admin credential should be issued without a second party who can act on it under a defined emergency process. Rehearse the succession path itself, not just the technical mechanism; a documented backup signer who has never actually executed a transaction is an unverified assumption, not a control.

Key controls for Part 4

- Treat contractor and short-term engagements as time-boxed, scoped grants with access expiry tied to the engagement's end date, and verify identity for any contractor touching code, infra, or funds with the same rigor as an employee.
- Recognize the DPRK fake-IT-worker and fake-recruiter patterns (OWASP WA05, WA15) by name in hiring and onboarding training, and require live, camera-on identity verification for every remote hire.
- Classify and register every wallet by tier (13.1), and never let a majority signer set on a treasury-tier wallet share a common employer or reporting line.
- Require independent, out-of-band calldata verification for any transfer above a defined threshold; a rendered UI summary is not proof of what a hardware wallet is actually signing (OWASP WA01).
- Run multisig signer onboarding and offboarding as a dedicated, on-chain lifecycle parallel to general employee provisioning, with a documented key ceremony and immediate on-chain removal on departure.
- Give every signer a fast, no-blame incident-reporting channel, and log near-misses alongside confirmed incidents.
- Document and rehearse succession for every key role before a departure forces it; QuadrigaCX and Multichain are what happens when that step is skipped.

Part V: Appendices

This part is the handbook's working reference layer, meant to be pulled up during a hire or a departure rather than read start to finish. It fixes the vocabulary from Parts 1 through 4 in a single glossary, packages the onboarding and offboarding checklists into printable, copy-ready templates, and points to the full bibliography behind every claim in the preceding parts.



Figure 1. How the appendices fit the lifecycle. The glossary is a lookup table for the terms used in the checklists; the checklists are the operational output of Parts 2 and 3; the reference list is the evidence trail behind both.

16. Appendix A: Glossary

The terms below are defined the way they are used in this handbook, not in the abstract. Each entry links back to the section that puts the term into practice, so a reader who lands here from a search engine can trace a definition to its operational context rather than stopping at a dictionary answer. Acronyms are expanded on first use, matching the convention used throughout Parts 1 through 4.

Acceptable Use Policy (AUP). The signed document setting rules for company devices, accounts, and data, including bring-your-own-device (BYOD) boundaries. Required of every hire before equipment or accounts are provisioned (Part 2, Section 2.2).

AC-2 / AC-6. The Account Management and Least Privilege controls in the Access Control family of [NIST Special Publication 800-53 Revision 5](#), cited throughout the handbook as the control basis for both provisioning and revocation timing (Part 2, Section 3.1; Part 3, Section 6.2).

Background verification. Pre-hire confirmation of identity, references, and where role-justified, a consumer report, run inside the Fair Credit Reporting Act (FCRA) and Equal Employment Opportunity Commission (EEOC) constraints that govern US hiring (Part 2, Section 2.1).

Blind signing. Approving a transaction based on a wallet interface's rendered summary without independently verifying the underlying calldata. The root failure mode behind the February 2025 Bybit theft (Part 4, Section 13.2).

Break-glass credential. A shared emergency-access credential intended for rare, high-urgency use. Every departing person who knew it triggers a mandatory rotation, not just a review (Part 3, Section 7.1).

Calldata. The raw, encoded data a blockchain transaction actually carries, as opposed to the plain-language summary a signing interface renders. A hardware wallet's own display or an independent decoder is required to verify it directly for large transfers (Part 4, Section 13.2).

Cold wallet / cold storage. Key custody kept fully offline, the highest-assurance tier in the treasury classification table and the appropriate home for reserve funds (Part 4, Section 13.1).

Deploy key. A credential authorizing a smart-contract deployment or upgrade. Treated as a rotation, not a revocation, item on departure because it may have been exported to a local environment (Part 3, Section 8.2).

DPRK remote-worker scheme. A campaign placing North Korean operatives in remote IT and engineering roles under false identities, for hard-currency revenue and, in some cases, insider access. A pre-onboarding red flag (Part 2, Section 2.1) and a contractor-lifecycle risk (Part 4, Section 11).

Endpoint Detection and Response (EDR). Monitoring software required on any company-issued device used for infrastructure, code, or treasury access, and the mechanism that first detected the payload in the 2024 KnowBe4 fake-hire incident (Part 4, Section 12).

Fair Credit Reporting Act (FCRA). The US law requiring standalone written disclosure, candidate authorization, and a pre- and post-adverse-action process before a consumer report can be used in a hiring decision ([FTC guidance for employers](#); Part 2, Section 2.1).

FIDO2 / passkey. A phishing-resistant authentication standard using public-key cryptography bound to the legitimate site, issued during onboarding training rather than left to a one-time-code app ([FIDO Alliance](#); Part 2, Section 4.1).

General Data Protection Regulation (GDPR). EU and UK data protection law whose Article 17 right to erasure governs how much of a departing employee's personal data must be deleted, subject to separate retention duties ([GDPR Article 17](#); Part 3, Section 10.2).

Hardware wallet. A dedicated device that generates and stores private key material without exposing it to a general-purpose computer, issued to every treasury or signer hire (Part 2, Section 3.4).

Hot wallet. An internet-connected wallet used for operational flows such as gas refills or market-making inventory, the lowest-assurance tier in the treasury classification and the one carrying the tightest balance caps (Part 4, Section 13.1).

Identity and Access Management (IAM). The systems (cloud IAM users and roles, identity providers) that grant and enforce access by identity rather than by shared credential (Part 3, Section 7.1).

Identity Governance and Administration (IGA). Tooling, or at minimum a maintained inventory, mapping every external account to a named owner so revocation does not depend on institutional memory (Part 3, Section 7.5).

Immediate vs. phased revocation. Immediate revocation cuts a credential the instant a departure trigger fires and is mandatory for the sensitive tier (infrastructure, deploy, wallets, multisig) regardless of departure type. Phased revocation stages lower-risk access across a notice period instead (Part 3, Section 6.2).

Insider threat. Risk from a person with legitimate access who uses or fails to safeguard it against the organization's interest, covered in depth in the Hiring, Remote Work, and Insider Threat Handbook (05).

Key ceremony. A witnessed, documented procedure for generating a new signer's key and cross-checking the resulting address over a verified channel before it is added on-chain (Part 4, Section 14.1).

Key custody agreement. The signed document assigning personal responsibility for a hardware wallet, seed material, or signer role, required before treasury or signer access activates (Part 2, Section 2.2).

Laptop farm. An operation that receives shipped company equipment on behalf of a fraudulently hired remote worker so their true location stays hidden, convicted in the 2025 Christina Chapman case (Part 2, Section 2.3; Part 4, Section 11).

Least privilege / Principle of Least Privilege (PoLP). The rule that a person's access matches their current role's actual need and nothing more, formalized in [NIST SP 800-53 AC-6](#) and applied through role templates rather than individual grants (Part 2, Section 3.1).

Material Non-Public Information (MNPI). Undisclosed information (an unreleased token listing, a pending governance change) that restricts a role holder's ability to trade the organization's token, covered in the trading policy signed at hire and reaffirmed at exit (Part 2, Section 2.2; Part 3, Section 10.1).

Mobile Device Management (MDM). Remote-wipe and enrollment tooling for company-issued phones and laptops, used both to enforce onboarding security baselines and to sanitize a device that cannot be physically recovered at offboarding (Part 3, Section 8.1).

Multi-Factor Authentication (MFA). Authentication requiring more than one factor. The handbook recommends a phishing-resistant form (FIDO2 or a passkey) over a one-time-code app wherever elevated or treasury access is involved (Part 2, Section 4.1).

Multi-Party Computation (MPC). A threshold-cryptography approach splitting key generation and signing across multiple parties so no single party holds the complete private key, relevant to custody-operator succession (Part 4, Section 15).

Multisignature wallet (multisig). A wallet, most commonly built on [Safe](#) (formerly Gnosis Safe), that only executes a transaction once a defined threshold of designated signers approves it on-chain, eliminating unilateral control by any one signer (Part 2, Section 3.4).

Non-Disclosure Agreement (NDA). The confidentiality agreement signed at hire and explicitly reaffirmed during the exit conversation, covering which obligations (trade secrets, unreleased roadmap detail) survive the employment relationship (Part 3, Section 10.1).

Offboarding. The revocation, asset recovery, documentation, and legal coordination process a departure triggers, covered end to end in Part 3.

Onboarding. The verification, provisioning, and training sequence running from an accepted offer to a fully audited Day 0, covered end to end in Part 2.

Orphaned account. A credential left active after its owner no longer has a legitimate need for it, catalogued as [MITRE ATT&CK technique T1078](#), [Valid Accounts](#), because nobody is watching for anomalous activity from it (Part 3, Section 6.3).

Payment Card Industry Data Security Standard (PCI DSS). The current version is [PCI DSS v4.0.1](#), the compliance framework whose scope extends audit-trail retention requirements for organizations handling cardholder data (Part 2, Section 5.2).

Privilege creep. The gradual accumulation of access an employee no longer needs as their role changes, the failure mode role-template reviews exist to catch (Part 1, Section 1.4).

Role-Based Access Control (RBAC). Granting access through team or group membership tied to a role rather than through individual, per-person grants, so that access disappears cleanly when membership ends (Part 2, Section 3.2).

Role template. A documented default for each of the four access categories (infrastructure, code, communications, treasury) that a given role should hold, approved centrally rather than negotiated per hire (Part 2, Section 3.1).

Sarbanes-Oxley Act (SOX). US financial-controls legislation that, where it applies, extends the retention period required for onboarding and offboarding audit-trail evidence beyond SOC 2's baseline (Part 2, Section 5.2).

Signer diversity. The requirement that a multisig's signer set not concentrate under a single employer or reporting line, since signer count alone does not resist coercion or collusion if the signers are not independent (Part 4, Section 13.1).

Single Sign-On (SSO). Federated login through one identity provider so that a single account disablement revokes access across every connected system at once, the mechanism that makes fan-out revocation in Part 3 tractable (Part 2, Section 3.2).

Succession planning. Documenting and rehearsing a backup for any key role so that role's absence, voluntary, coerced, or fatal, does not freeze or lose funds (Part 4, Section 15).

swapOwner. The `Safe OwnerManager` function that atomically replaces one multisig owner with another in a single transaction, preferred over a separate remove-then-add sequence (Part 3, Section 7.4).

System and Organization Controls 2 (SOC 2). An assurance framework, administered by the [American Institute of Certified Public Accountants \(AICPA\)](#), whose Trust Services Criteria CC6 (logical access controls) most Web3 organizations handling customer or partner data eventually need to demonstrate against (Part 2, Section 5.2).

System for Cross-domain Identity Management (SCIM). A protocol, defined in [RFC 7644](#), used to synchronize account state across connected systems and generate the timestamped deprovisioning evidence an offboarding audit needs (Part 3, Section 9.2).

Threshold. The minimum number of a multisig's designated signers whose approval is required before a transaction executes (Part 2, Section 3.4).

Timelock. A mandatory delay enforced before a large withdrawal or governance action executes, giving an on-call team time to detect and halt a compromised signing session before funds move (Part 4, Section 13.2).

Treasury tier. The classification assigned to every wallet an organization controls (operational, working capital, treasury reserve, emergency/pause authority), which determines its enhanced controls (Part 4, Section 13.1).

Wrench attack. Physical coercion of a keyholder to force a signature or key handover, a risk signer diversity and threshold design are meant to blunt (Part 4, Section 13.1).

17. Appendix B: Onboarding Checklist (Printable)

This checklist consolidates Part 2 into a single document a security or HR lead can print or paste into a runbook tool. It is organized by phase rather than by system, matching the sequencing rule from Chapter 2: verification and acknowledgments precede equipment and account provisioning, and elevated or treasury access waits on completed training. Every line references the section that explains why the step exists.

Use one copy of this template per hire. Leave no line blank: an item that genuinely does not apply (for example, treasury access for a role with no signer responsibility) should be marked N/A with a reason, not left empty, because an empty line is indistinguishable from a forgotten one during a later audit. The completed checklist itself becomes part of the audit trail in Section 5.2 and should be filed, not discarded, once every item is checked.

Onboarding record

- Candidate / new hire name: _____
- Role and role template applied: _____
- Start date (Day 0): _____
- Access tier: Standard ☐ Elevated ☐ Treasury/Signer ☐
- Provisioning owner: _____
- Reviewing security lead (must differ from provisioner): _____ Date: _____

Phase 1: Pre-onboarding (complete before Day 0)

- ☐ Identity verified via live, camera-on video call with government-issued ID (2.1)
- ☐ Independent reference check completed, using an independently sourced contact number (2.1)
- ☐ Consumer report or background check completed with FCRA disclosure and signed authorization on file, where role-justified (2.1)
- ☐ Equipment shipping address verified against the identity documents on file (2.3)
- ☐ NDA and IP assignment signed (2.2)
- ☐ Acceptable Use Policy (AUP) signed (2.2)
- ☐ Code of conduct signed (2.2)
- ☐ MNPI and trading policy signed, if role has token or governance visibility (2.2)
- ☐ Security and OpSec pledge signed (2.2)
- ☐ Key custody agreement signed, if role is treasury, deploy-key, or signer (2.2)
- ☐ Device policy (company-issued vs. BYOD) determined by role risk (2.3)
- ☐ Baseline accounts (email only) pre-provisioned; no elevated access created yet (2.3)

Phase 2: Access provisioning (Day 0)

- ☐ Role template applied for infrastructure, code, and communications (3.1)
- ☐ SSO enrollment complete; no standalone credentials created outside the identity provider (3.2)
- ☐ Repository access granted via team membership, not a direct individual grant (3.2)
- ☐ Branch protection confirmed on any repository the new hire can affect (3.2)
- ☐ Communications tools provisioned at standard, non-admin tier (3.3)
- ☐ Hardware security key (FIDO2) issued and enrolled (4.1)
- ☐ Treasury or signer access provisioned only after the training gate below clears, via a threshold-gated on-chain transaction, never an off-chain override (3.4)
- ☐ Hardware wallet issued; seed material generated offline on-device; never transmitted electronically (3.4)
- ☐ All secrets handed off through a secrets manager or one-time, self-destructing link; none left in persistent chat or email (3.5)
- ☐ New hire has rotated every initial credential on first use (3.5)

Phase 3: Training (complete before elevated access activates)

- ☐ Phishing and social-engineering recognition module completed (4.1)
- ☐ Credential and secrets hygiene module completed (4.1)
- ☐ Wallet and signing OpSec module completed, if treasury or signer role (4.1)
- ☐ Physical and device security module completed (4.1)
- ☐ Incident reporting channel and escalation path confirmed understood in writing (4.2)

Phase 4: Documentation and close-out

- ☐ Every provisioning action logged with requestor, approver, scope, and timestamp (5.2)
 - ☐ Acknowledgment and training completion timestamps recorded (5.2)
 - ☐ Checklist reviewed and signed off by someone other than the provisioner (5.2)
 - ☐ Checklist filed in the audit trail for the retention period compliance requires (5.2)
-

18. Appendix C: Offboarding Checklist (Printable)

This checklist consolidates Part 3 into a single printable document, built to run identically whether the trigger is a quiet, planned resignation or a same-day emergency lockout; an unplanned departure simply compresses every phase from weeks into hours rather than skipping any of them. The sensitive-tier lockout in Phase 2 is marked same-day always, because infrastructure, deploy, wallet, and multisig access move through immediate revocation regardless of how amicable or well-planned the departure is.

As with the onboarding template, mark any inapplicable line N/A with a reason rather than leaving it blank, and route the completed checklist to the audit step in Phase 5 rather than treating a fully checked Phase 4 as the end of the process. A checklist nobody independently verifies is a claim, not a control.

Offboarding record

- Departing person's name: _____
- Role and signer status (Yes / No): _____
- Departure type: Planned ☐ Unplanned ☐
- Trigger date and time (T0): _____
- Revocation owner: _____
- Independent audit reviewer (must differ from revocation owner): _____
- Date: _____

Phase 1: Trigger and classification (T0)

- ☐ Departure classified as planned or unplanned, per Section 6.1's trigger table
- ☐ Revocation model selected; sensitive tier routed to immediate revocation regardless of classification (6.2)
- ☐ IT, Security, Legal, and the departing person's manager notified (target: T0 + 1 hour)

Phase 2: Sensitive-tier lockout (T0, same day, always)

- ☐ Cloud IAM roles, VPN certificates, and SSH keys revoked (7.1)
- ☐ Access keys deleted outright, not merely a console password deactivated (7.1)
- ☐ CI/CD secrets and deploy keys the person could read rotated (7.2)
- ☐ Multisig `swapOwner` transaction proposed; remaining signers collect threshold confirmations (7.4)
- ☐ New owner set and threshold independently verified on a block explorer (7.4)
- ☐ Single-signature deploy or hot-wallet keys rotated; residual balances swept (7.4)

Phase 3: Standard-tier lockout (T0 through last working day)

- ☐ SSO account disabled (7.1)
- ☐ Email deactivated per the organization's forwarding or legal-hold policy, not deleted immediately (7.3)
- ☐ Chat and collaboration access removed (Slack, Discord, Telegram, and equivalents) (7.3)
- ☐ Bot tokens, webhooks, and integration credentials the person could have generated rotated (7.3)
- ☐ Registrar, DNS, and external SaaS admin access revoked (7.5)

Phase 4: Asset and key recovery

- ☐ Company devices collected, or remote-wiped same day if not returned (8.1)
- ☐ Hardware security keys and hardware wallets deregistered or physically collected (8.1)
- ☐ Access badge deactivated same day (8.1)
- ☐ Recovered devices sanitized per NIST SP 800-88 Rev. 1 before reissue (8.1)
- ☐ Any key the person could plausibly have exported or copied fully rotated, not merely revoked (8.2)
- ☐ Handover documentation updated: ownership records, [README / CODEOWNERS](#), secrets-escrow role reassigned to a named successor (8.3)

Phase 5: Legal, audit, and close-out

- ☐ NDA and IP assignment obligations reaffirmed in the exit conversation (10.1)
 - ☐ Data retention and erasure obligations reviewed against applicable jurisdictional requirements (10.2)
 - ☐ Personal devices and accounts checked for lingering organizational data or access tokens; return confirmed (10.2)
 - ☐ Independent verification 24 to 72 hours out: zero active sessions, zero valid API keys or tokens, zero remaining multisig ownership (9.2)
 - ☐ SCIM or identity-provider deprovisioning logs, or equivalent timestamped evidence, retained (9.2)
 - ☐ Checklist reviewed and formally closed by the security lead within 30 days of T0 (9.1)
-

19. Appendix D: References and Further Reading

The full, deduplicated bibliography for this handbook lives in a separate file, `references.md`, so the source list can be maintained independently of the narrative parts. Every inline citation across Parts 1 through 4, and in Appendix A above, points to a primary source: a standard's publication page, a regulator's guidance document, an incident's own disclosure or a credible forensic write-up, or a named tool's documentation. `references.md` collects those links in one place, grouped so a reader chasing a specific kind of source does not have to re-scan four parts of prose.

Category	What it holds	Representative sources
Standards and Frameworks	Government and industry standards this handbook's controls trace back to	NIST SP 800-53 Rev. 5, NIST SP 800-88 Rev. 1, ISO/IEC 27001:2022, PCI DSS v4.0.1, GDPR, RFC 7644 (SCIM), MITRE ATT&CK
Incidents and Case Studies	Named breaches, thefts, and infiltration cases cited as evidence for a control	Ronin Network (2022), QuadrigaCX (2018), Bybit (2025), Coinbase (2025), the Christina Chapman laptop-farm case (2025), KnowBe4's fake-hire disclosure (2024)
Tools	Vendor and project documentation for named tools referenced in configuration examples	Safe (<code>OwnerManager.sol</code>), GitHub organization and Actions APIs, FIDO Alliance passkey documentation
Further Reading	Cross-references to companion OWASP SCS handbooks and standards	OWASP Web3 Attack Vectors Top 15, SCSVS, SCSTG, SCWE, Handbooks 01, 02, 05, 06, and 11

Treat `references.md` as the place to verify a claim before repeating it externally, particularly for the incident case studies, since public reporting on recent breaches is revised as forensic findings mature.

Key controls for Part 5

- Keep this glossary within reach for any reader who joins the lifecycle process mid-stream, whether they are new to the security team or a manager running their first offboarding.
- Run one Appendix B checklist per hire and one Appendix C checklist per departure; a checklist that is not actually executed and signed off is not a control.
- Mark inapplicable checklist lines N/A with a stated reason instead of leaving them blank, so a later audit can distinguish a deliberate skip from a missed step.
- Route both checklists into the audit trail (Part 2, Section 5.2; Part 3, Section 9.2) once complete, since the checklist plus its independent review together are the evidence a SOC 2 or similar audit will ask for.
- Verify a claim against `references.md` before repeating it outside the handbook, especially for incident details that may have been updated since this text was written.

This is the final part of the OWASP SCS Employee Lifecycle Security Handbook.

Appendix C: References and Further Reading

This appendix collects every external source cited across the Employee Lifecycle Security handbook, grouped by type for easier follow-up research.

Standards and Frameworks

- NIST SP 800-207, Zero Trust Architecture
- NIST SP 800-34 Rev. 1, Contingency Planning Guide for Federal Information Systems
- NIST Special Publication 800-53 Revision 5
- NIST Special Publication 800-88 Revision 1
- RFC 7644, SCIM Protocol
- OWASP Secrets Management Cheat Sheet
- OWASP Smart Contract Security Verification Standard (SCSVS)
- OWASP Web3 Attack Vectors Top 15
- GDPR Article 17
- ISO/IEC 27001:2022 Annex A control 5.18, Access Rights
- PCI DSS v4.0.1
- American Institute of Certified Public Accountants (AICPA), SOC 2
- MITRE ATT&CK technique T1078, Valid Accounts
- MITRE ATT&CK T1531, Account Access Removal
- EEOC's joint guidance with the FTC on background checks
- FTC guidance for employers using consumer reports

Incidents and Case Studies

- Bybit hack summary and attribution
- Christina Chapman case summary
- Coinbase 2025 data breach, Wikipedia summary of public disclosures
- LastPass breaches disclosed in 2022
- Wikipedia: North Korean remote worker infiltration scheme
- Wikipedia: QuadrigaCX
- Wikipedia: Ronin Network
- Halborn, "Explained: The Ronin Hack (March 2022)"
- KnowBe4, "How a North Korean Fake IT Worker Tried to Infiltrate Us"
- FBI IC3 PSA 231018

Tools and Documentation

- [GitHub documentation, removing a member from your organization](#)
- [Safe smart contracts, `OwnerManager.sol`](#)
- [Safe](#)

Further Reading

- [NIST's identity and access management \(IAM\) program](#)
- [FIDO Alliance, passkeys](#)
- [Chainalysis's 2025 Crypto Crime Report](#)
- [Verizon's Data Breach Investigations Report](#)
- [Ponemon/Proofpoint Cost of Insider Threats Report](#)